



Universidad Internacional de La Rioja
Escuela Superior de Ingeniería y Tecnología

Máster Universitario en Ciberseguridad

**Auditoría de ciberseguridad y diseño de métricas
de cumplimiento humanizadas basadas en NIST y
NIS2 en Chile**

Trabajo fin de estudio presentado por:	Yessica Betzave Bolívar Romero
Tipo de trabajo:	Desarrollo de metodología
Director/a:	Manuel Antonio Pérez Chaparro
Fecha:	24-06-2026

Resumen

En la actualidad la mayoría de los resultados de las auditorías de ciberseguridad se fundamentan en métricas de indicadores técnicos como controles normativos, alertas y detección de vulnerabilidades comprensibles y útiles para equipos técnicos, pero inteligibles para la responsabilidad y uso estratégico de la dirección en las organizaciones. Considerando la brecha por ausencia de modelos o guías que incorporen la humanización de las métricas en la interpretación de gobernanza y gestión del riesgo en seguridad. Este TFM propone un catálogo de controles aplicados en un cuadro de mando ejecutivo en Excel que guía y vincula los requisitos de marcos internacionales y la ley marco de Ciberseguridad N°21.663 más relevantes; transformando los datos técnicos aislados e impersonales de los indicadores de desempeño (KPIs) y riesgo (KRIs) en métricas humanizadas de cumplimiento y exposición al riesgo, que conectan la comprensión y acción con la reacción e interpretación facilitando la toma de decisiones.

Palabras clave: Auditoría de ciberseguridad, NIST CSF, NIS2, métricas humanizadas y métricas de ciberseguridad.

Abstract

Currently, most cybersecurity audit results are based on technical metrics such as regulatory controls, alerts, and vulnerability detection metrics that are understandable and useful to technical teams but not easily comprehensible for management's strategic use and accountability within organizations; Given the gap caused by the lack of models or guidelines that incorporate the humanization of metrics into the interpretation of security governance and risk management, this TMF proposes a catalog of controls applied in an Excel executive scorecard that guides and links the most relevant requirements of international frameworks and Cybersecurity Framework Law No. 21,663; transforming the isolated and impersonal technical data of performance indicators (KPIs) and risk indicators (KRIs) into humanized metrics of compliance and risk exposure that connect understanding and action with reaction and interpretation, thereby facilitating decision making.

Keywords: Cybersecurity audit, NIST CSF, NIS2, humanized metrics, and cybersecurity metrics.

Índice de contenidos

1	Introducción	8
1.1	Motivación	9
1.2	Planteamiento del problema	10
1.3	Estructura del trabajo	11
2	Estado del arte	14
2.1	Antecedentes de investigación	14
2.2	Bases teóricas	15
2.2.1	NIST Cybersecurity Framework: funciones, controles y métricas.....	15
2.2.2	NIS2 Directive: requisitos, sectores críticos, obligaciones de reporte.....	19
2.2.3	Definiciones de Ciberseguridad desde diferentes ámbitos.....	22
2.2.4	NIST SP 800-53.....	23
2.2.5	Humanización de métricas	24
2.2.6	Ciberseguridad con la ISO 27032.....	25
2.2.7	Chile en Informe del Índice de Ciberseguridad Global de la UIT.....	25
2.2.8	Auditorías de Ciberseguridad	26
2.2.9	Auditorías norma ISO 27001	26
2.2.10	Metodología COBIT.....	28
2.2.11	Metodología Design Science Research (DSR)	28
2.3	Bases legales de la investigación	29
2.3.1	Ley N°21.663/2024 Ley Marco de Ciberseguridad en Chile.....	29
2.3.2	Ley N°21.459/2022 sobre Delitos Informáticos en Chile	29
2.3.3	Normativas sectoriales en Chile	30
2.3.4	Gobierno Corporativo y la importancia de la cultura de ciberseguridad. Rol del Directorio.....	31

2.3.5	Aspectos legales futuros pendientes en el marco de ciberseguridad en Chile..	31
2.4	Conclusión.....	32
3	Objetivos concretos y metodología de trabajo.....	33
3.1	Objetivo general.....	33
3.2	Objetivos específicos	33
3.3	Fases design science research (DSR).....	34
3.3.1	Fase 1: Revisión y análisis documental.....	34
3.3.2	Fase 2: Diseño del catálogo de controles integrado	35
3.3.3	Fase 3: Diseño del sistema de métricas KPI/KRI.....	35
3.3.4	Fase 4: Recolección de Datos y medición Inicial y análisis de Brechas y Priorización.....	35
3.3.5	Fase 5: Implementación tableros de mando.....	35
3.3.6	Fase 6: Validación mediante caso de estudio	36
4	Desarrollo específico de la contribución.....	38
4.1	Desarrollo de la metodología	38
4.1.1	Identificación de requisitos	38
4.1.2	Descripción de la metodología	41
4.1.3	Fundamento Metodológico: Design Science Research (DSR)	41
4.1.4	Evaluación.....	48
5	RESULTADOS	49
5.1	Análisis estado de la seguridad de la organización	49
5.2	Análisis del nivel de cumplimiento normativo ley 21.663.....	49
5.3	Análisis integral de los indicadores humanizados	49
6	Conclusiones y trabajo futuro	51
7	Referencias bibliográficas	54

Anexo A.....	57
--------------	----

Índice de figuras

Figura 1 Secciones de Trabajo de Investigación	13
Figura 2 CSF Funciones	17
Figura 3 Pasos para crear y utilizar un perfil organizacional de CSF	17
Figura 4 Niveles CSF para la gobernanza y gestión del riesgo de ciberseguridad.....	19
Figura 5 Diagrama Proceso Design Science Research (DSR)	28
Figura 6 Bocetos de vista idea de tablero de mando	36
Figura 7 Planificación metodológica del trabajo de investigación	36
Figura 8 Arquitectura del modelo flujo modelo de auditoría de ciberseguridad con métricas humanizadas.....	42
Figura 9 Tablero de mando estado de la seguridad	46
Figura 10 Tablero de mando nivel de cumplimiento normativo Ley 21.663	46
Figura 11 Tablero ejecutivo Indicadores Humanizados	47

Índice de tablas

Tabla 1 CSF 2.0 Nombres e identificadores de funciones y categorías principales	57
Tabla 2 Requisitos de la directiva NIS2.....	57
Tabla 3 Plantilla de auditoría de brechas para la auditoría de cumplimiento de NIS 2	58
Tabla 4 Controles NIST 800-53	59
Tabla 5 Comparación entre NIST CSF 2.0, Ley 21.663 y NIS2 frente a la humanización de métricas en ciberseguridad.	60
Tabla 6 Roles y actores del modelo de auditoría de ciberseguridad	60
Tabla 7 Dominios de control humanizados del modelo	61
Tabla 8 Descripción resumen marco normativo la Ley 21.663	62
Tabla 9 Matriz de Alineación Cruzada NIST CFS 2.0-NIS2-Ley 21.663 (GOBERNAR-IDENTIFICAR-PROTEGER).....	63
Tabla 10 Matriz de Alineación Cruzada NIST CFS 2.0-NIS2-Ley 21.663 (DETECTAR-RESPONDER-RECUPERAR)	64
Tabla 11 Catalogo de Indicadores KPI/KRI humanizados Dominios Gobernar (GV) –Identificar (ID)- Detectar (DE)	65
Tabla 12 Catalogo de Indicadores KPI/KRI humanizados Dominios (RS)-RECUPERAR (RC)	66
Tabla 13 Plantilla de Auditoría de Brechas.....	67
Tabla 14 Plantilla Cuadro de Mando Ejecutivo de Ciberseguridad	68
Tabla 15 Resultados de la evaluación por juicio de expertos (escala Likert 1-5).....	69
Table 16 Instrumento de Recolección de Información del Modelo.....	70
Tabla 17 Indicadores humanizados vs técnicos	71

1 INTRODUCCIÓN

La acelerada transformación digital de las últimas décadas ha redefinido los parámetros de seguridad y su aplicación en organizaciones a nivel global. En América Latina, y particularmente en Chile, este proceso se ha manifestado en un crecimiento exponencial de la adopción de tecnologías de la información, la interconexión de sistemas gubernamentales, financieros e industriales, así como en la promulgación de nuevas regulaciones en materia de ciberseguridad. En este panorama fragmentado y desafiante los países exploran y adoptan diversos enfoques, técnicas y marcos normativos para ir a la par con la homogeneidad, madurez y sostenibilidad de su ciberseguridad aún en desarrollo.

Para ilustrar esto, los marcos internacionales reconocidos como el NIST Cybersecurity Framework (CSF) y la Directiva NIS2 de la Unión Europea, son las referencias directivas y el baseline de referencia en cumplimiento, comunicación y comprensión del estado de la ciberseguridad para los directorios y gerencias sin formación técnica especializada e indicadores de resultados complejos.

Ahora con la implementación de la ley marco de Ciberseguridad N°21.663 en Chile se introduce un cambio clave la ciberseguridad cambia de paradigma: transitan de una gobernanza organizacional con responsabilidad legal genérica y técnica (propietaria), aún “gobierno interno de ciberseguridad” que escala al nivel de los directorios (alta gerencia) con responsabilidad y sanciones sino gestionan la prevención, detección y respuesta a incidentes; según los estándares de protección de servicios críticos ante las autoridades de control.

Ante la ausencia de instrumentos que integren los marcos y el vacío práctico de métricas humanizadas en ciberseguridad en Chile, el presente trabajo proyecta la construcción de un marco metodológico guía que reduzca la brecha y la desconexión entre lo técnico, estratégico y humano en el gobierno de la ciberseguridad y además pueda ser adaptado por cualquier organización que busque evaluar y elevar su madurez en ciberseguridad.

1.1 Motivación

Esta investigación surge de dos hitos novedosos de la ciberseguridad en Chile, la entrada en vigencia de la Ley Marco de Ciberseguridad N°21.663 en enero de 2025, regula y exige a las instituciones públicas y privadas las medidas de gobernanza, auditorías y reportes y de igual forma, la creación de la Agencia Nacional de Ciberseguridad (ANCI), que otorgó un período de construcción y adaptación antes de fiscalizar el cumplimiento y demostración de las exigencias normativas con instrumentos.

En coherencia con las demandas de la globalización, la sociedad y comercio la seguridad es estratégica para todos, los países homologan y adaptan sus marcos nacionales y actualización legislativa con los marcos internacionales comprobados NIST Cybersecurity Framework (CSF) (enfoque técnico-operativo) y la Directiva NIS2 de la Unión Europea (enfoque gobernanza y supervisión para la organización y sus directorios). Sin embargo, a pesar de las buenas prácticas e indicadores estandarizados las metodologías no son suficientes, el lenguaje técnico en sí mismo, es un obstáculo que dificulta que los líderes interpreten los resultados del riesgo y puedan adoptar medidas de mitigación e inversión con decisiones informadas.

En base a las consideraciones anteriores, se puede señalar que la ciberseguridad no sólo depende de la tecnología y las reglas de los marcos; su sostenibilidad está en útil, lo práctico y medible para las personas. Ante esta situación esta investigación esboza cómo conectar la dimensión técnica de la ciberseguridad con la dimensión humana y organizacional, con un modelo de auditoría de ciberseguridad de métricas humanizadas; que permita medir el desempeño del estado de la seguridad más allá de un checklist normativo, que traduzca las métricas con un lenguaje (práctico/relevante) para la dirección y sume valor a la gobernanza y comunicación estratégica.

A los efectos del cambio, la nueva Ley marco de Ciberseguridad N°21.663 es una oportunidad para innovar con métricas humanizadas que conecten lo técnico-humano y estratégico, a través de una guía e instrumentos de medición, auditoría y reportes ejecutivos para los responsables de seguridad que comparten el estado del cumplimiento y riesgo al directorio; que toma las decisiones estratégicas, asignan el financiamiento y participa en el discernimiento activo del cumplimiento legal y normativo.

1.2 Planteamiento del problema

Los requisitos de los marcos internacionales antes señalados y el contexto normativo chileno actual, han generado dificultades para que las organizaciones logren el grado de cumplimiento y madurez de organización en ciberseguridad. Están en un proceso de ensayo y error donde alinean y nivelan sus insuficiencias técnicas, controles, herramientas, personas e inversión para demostrar su nivel de cumplimiento ante la exposición del riesgo ante las autoridades.

La revisión de la bibliográfica y los marcos normativos de ciberseguridad revelan que no contiene de manera explícita indicadores humanizados, se centran en avances y actualizaciones de controles técnicos, gobernanza, procesos de gestión del riesgo y obligaciones de cumplimiento normativo con aportes de indicadores técnicos.

De modo que hay un vacío de mecanismos, herramientas y metodologías para que los directorios y demás perfiles no técnicos reciban reportes en un lenguaje comprensible, esta tendencia emergente hace que la humanización de la seguridad sea cada vez más necesaria.

Adicional a lo anterior, también está la presión de los plazos para crear el “gobierno interno de ciberseguridad”; las entidades responden de manera reactiva y con capacidad limitada ante los incidentes de ciberseguridad constantes que no fortalecen su resiliencia y madurez.

En virtud de lo derivado de los cambios, las organizaciones se pierden entre la prioridad de los controles técnicos de su infraestructura y acatar un marco legal o normativo, entonces, deben evaluar como actualizar su situación real considerando estos desafíos: *Normativa:* Chile carece de un estándar nacional de ciberseguridad equivalente a marcos internacionales y leyes de seguridad sin reglamentos, lo que genera enfoques heterogéneos y dificulta la estandarización dentro y fuera, no obstante, está en construcción el cómo se exige la demostración de una gestión activa de la ciberseguridad con indicadores trazables y comprensibles, así como, su eficacia presupuestaria en inversiones de ciberseguridad.

Metodológica: no existen herramientas de auditoría estructuradas y humanizadas que permitan evaluar de manera sistemática el nivel de cumplimiento de controles técnicos y organizativos; creando una desconexión entre tecnología y el directorio que toma decisiones de gobernanza desinformadas y no pueden evaluar una correcta postura de riesgo cuando los reportes están expresados en lenguaje técnico.

Métricas técnicas incomprensibles: existe una brecha significativa entre la información de los indicadores tradicionales de los sistemas de seguridad (SOC, SIEM, herramientas de análisis de vulnerabilidades) y los expresados en métricas técnicas como CVSS scores o número de CVEs; no resultan comprensibles o accionables para los perfiles no técnicos de la alta dirección y el directorio, se entorpece la interpretación para la toma de decisiones estratégicas de inversión e innovación.

Desde este punto de vista, la autora plantea la siguiente pregunta de investigación:

¿De qué manera la traducción de resultados de los indicadores técnicos a métricas humanizadas facilita la entrega de reportes ejecutivos al directorio, transformando datos complejos en decisiones de negocio estratégicas el marco de la Ley N°21.663 y los estándares NIST CSF y NIS2?

Resulta evidente que los directorios y los usuarios no técnicos, no necesitan saber el dato específico del número de vulnerabilidades críticas, sino saber interpretar, como estas impactan el estado de la seguridad, la continuidad operativa, su reputación y patrimonio.

Con el diseño de un modelo de auditoría de ciberseguridad basado en métricas de cumplimiento humanizadas, alineado con las exigencias normativas asociadas a la Ley N°21.663, NIST CSF y NIS2; la propuesta incorpora herramientas de visualización y evaluación con un cuadro de mando ejecutivo en Excel, que modela la interpretación de los resultados de indicadores clave de desempeño (KPIs) e indicadores clave de riesgo (KRIs) con preguntas que significativas y humanizadas que transforman indicadores complejos en información clara, útil y accionable sobre el nivel de cumplimiento, supervisión y la exposición al riesgo.

1.3 Estructura del trabajo

Esta investigación se organiza siguiendo una estructura académica que permite abordar de manera clara y sistemática el problema de estudio, sus fundamentos teóricos y las soluciones propuestas.

Resumen: proporciona una visión clara del proyecto respecto a la necesidad de un modelo de auditoría de ciberseguridad en Chile, la integración de NIST CSF y NIS2 y las principales conclusiones esperadas sobre métricas de cumplimiento y herramientas de reporte.

Introducción: su propósito es guiar y orientar con una síntesis al lector desde el inicio del trabajo, expone porque la elección del tema, cuál es su relevancia y cómo se abordará a lo largo del trabajo.

Objetivos y metodología: Define el objetivo general, los objetivos específicos y la metodología de desarrollo del trabajo.

Estado del arte: recopila los antecedentes normativos y científicos relevantes, situando la investigación en el contexto internacional y nacional, también, permite identificar qué aportes o desafíos conlleva este trabajo.

Desarrollo: presenta el modelo de auditoría con la integración de NIST CSF y NIS2, el catálogo de controles, el sistema de métricas KPI/KRI, simulación del escenario de auditoría y tableros de mando (visualización y reporte ejecutivo).

Conclusiones y Trabajos Futuros: sintetiza los resultados, propone líneas de investigación futuras y analiza si se cumplieron los objetivos; de igual manera, es un espacio para reflexionar sobre las limitaciones y oportunidades en el desarrollo de la investigación.

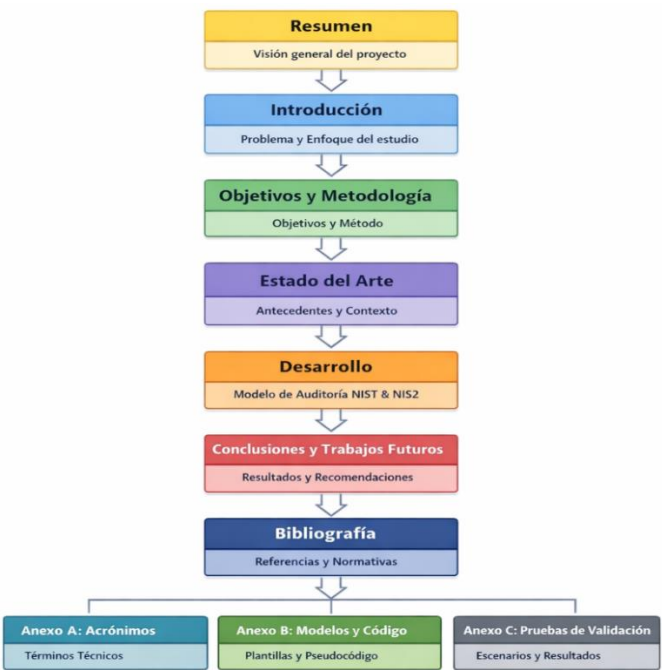
Bibliografía: incluye referencias académicas y normativas: NIST CSF 2.0, Directiva NIS2, Ley Marco de Ciberseguridad chilena, literatura científica sobre auditorías de ciberseguridad.

Anexo A: acrónimos lista de términos técnicos y framework

Anexo B: modelos de plantillas de auditoría, pseudocódigo de métricas y fórmulas de cálculo.

Anexo C: pruebas de validación Escenarios simulados de auditoría, resultados de aplicación del modelo en organizaciones piloto, análisis de cumplimiento y madurez.

Figura 1 Secciones de Trabajo de Investigación



Fuente: Elaboración propia

2 ESTADO DEL ARTE

2.1 Antecedentes de investigación

Fonseca (2025), en su trabajo denominado “La ingeniería social y el factor humano en la ciberseguridad: La ciberinteligencia como vector de transformación del eslabón más débil a la defensa más fuerte”, expone el vector del factor humano como la oportunidad de transformar al eslabón más débil a la defensa más fuerte integrando los marcos NIST CSF 2.0, CIS Controls y MITRE ATT&CK; su aporte infiere el rol de valor del factor humano con el entendimiento de lo técnico con métricas de ciberseguridad humanizadas. Si el usuario no es considerado una vulnerabilidad principal puede convertirse en un activo estratégico de defensa con conocimiento y juicio; este mismo orden de ideas, el autor reconoce que los marcos regulatorios y técnicos de seguridad no depende únicamente de controles tecnológicos, sino también de la conciencia y comportamiento humano, lo que abre un espacio crítico para adaptar estas métricas al contexto chileno y fortalecer la gobernanza corporativa frente a amenazas digitales.

González (2024), en su tesis titulada “Modelo de gestión de riesgos de ciberseguridad para instituciones financieras chilenas,”, plantea una investigación centrada en la aplicación de marcos internacionales como NIST SP 800-53 y el NIST CSF adaptados al contexto chileno; su modelo integral de gestión de riesgos de ciberseguridad para entidades de financieras, expone la complejidad de armonizar y alinear la normativa local con los marcos normativos internacionales, el gobierno corporativo de riesgo, la madurez organizacional y la cultura de seguridad. Como base comparativa González refuerza tres puntos de interés: la idea de la participación del directorio en la gestión del riesgo alineado con la ley 21.663, el comportamiento humano como cimiento de la cultura organizacional y la gobernanza corporativa y en último término la resiliencia organizacional, no sólo se trata de implementar modelos que cumplan normativas, sino que las instituciones desarrollen capacidades adaptación y evolución ante los resultados de las amenazas y riesgos.

Tanto Fonseca (2025) como González (2024) coinciden con la intención metodológica y práctica del modelo de propuesta del estudio que busca cerrar la brecha con un marco unificado que simplifique la complejidad técnica, la protección de activos digitales y la gestión integral del riesgo; al adaptar marcos internacionales de ciberseguridad y la gobernanza de IT

al contexto chileno. Así mismo reconocen, la importancia de las personas en el sistema gobierno de la ciberseguridad y la adopción espontánea de la interpretación las métricas y controles técnicos como oportunidad en cultura organizacional del riesgo.

Lecca-Rengifo, Paz-Medrano y Mendoza de los Santos (2025), en su investigación titulada “Impacto de los marcos de gobierno de TI en la seguridad de la información de las organizaciones”, analizan cómo la aplicación de frameworks como COBIT, NIST CSF e ISO 27001 pueden influir en la protección de los activos digitales y en la madurez organizacional. Su aporte radica en demostrar el impacto y resultados de los marcos metodológicos en la gobernanza de TI y la seguridad de la información, proporciona un punto de vista comparativo entre los marcos de gobierno y como ayudan mejorar y preservar la seguridad. En este contexto su investigación, refuerza la insuficiencia en la humanización de métricas o procedimientos que entreguen información accionable y manejable para las personas de los directorios sin formación especializada.

Este vacío que debe ser subsanado en la propuesta de investigación de autora, para ofrecer una nueva forma de comunicar la evaluación de la madurez y el estado de la ciberseguridad con su diseño de un marco unificado con KPIs/KRIs comprensibles y ejecutivos y gestionados por los responsables de la seguridad y áreas de IT.

2.2 Bases teóricas

2.2.1 NIST Cybersecurity Framework: funciones, controles y métricas.

2.2.1.1 Marco de Ciberseguridad (CSF) 2.0 del NIST

Como indica Pascoe (2024), NIST es un marco guía para las empresas, organismos públicos y diversas organizaciones que ofrece un lenguaje común para gestionar riesgos digitales, orienta sobre prácticas y controles útiles para ayudar a alcanzar los resultados, empleando una clasificación general que puede ser aplicada en cualquier entidad sin limitaciones de tamaño o nivel de madurez. En este mismo orden de ideas, el marco se organiza en seis funciones claves Gobernar, Identificar, Proteger, Detectar, Responder y Recuperar con métodos específicos para comprender, evaluar, priorizar y comunicar cada iniciativa de protección con una visión integral de la gestión del riesgo de seguridad cibernética.

En el documento (National Institute of Standards and Technology, 2024).se abordan la descripción general del marco NIST CSF 2.0, a continuación, se desarrolla la interpretación y breve de las partes y áreas para el desarrollo del modelo:

2.2.1.2 Componentes

- CSF principal (¿Qué debemos lograr en ciberseguridad?): plantea la taxonomía de resultados debería alcanzar una organización en ciberseguridad de alto nivel en la gestión del riesgo, es un mapa que indica los objetivos a cumplir incluye funciones y categorías.
- Perfiles organizativos (¿Dónde estamos hoy y dónde queremos llegar?): permiten describir la postura actual o futura de seguridad de una organización en relación con los resultados del CSF.
- Niveles del CSF (¿Qué tan madura es nuestra gestión de ciberseguridad?): permiten medir el grado de gobernanza, gestión y madurez de la organización frente a la gestión del riesgo.

2.2.1.3 Funciones del NIST CSF 2.0

Describe en la gestión de riesgos de ciberseguridad en seis funciones principales (Govern, Identify, Protect, Detect, Respond, Recover), así como cada una con de categorías específicas que permiten estructurar indicadores y métricas (National Institute of Standards and Technology, 2024) (Ver Tabla 1 CSF 2.0 Nombres e identificadores de funciones y categorías principales).

- Gobernar: se establecen, comunican y monitorean la estrategia, las expectativas y la política de gestión de riesgos de seguridad cibernética de la organización.
- Identificar: se comprenden los riesgos de seguridad cibernética actuales de la organización
- Proteger: se utilizan salvaguardas para gestionar los riesgos de seguridad cibernética de la organización.
- Detectar: se detectan y analizan posibles ataques y vulneraciones de seguridad cibernética.
- Responder: se toman medidas con respecto a un incidente de seguridad cibernética detectado.
- Recuperar: se restauran los activos y las operaciones afectados por un incidente de seguridad cibernética.

Figura 2 CSF Funciones



Fuente: (National Institute of Standards and Technology, 2024)

2.2.1.4 CSF Profiles

Son herramientas que permiten a las organizaciones evaluar su postura de ciberseguridad, definir objetivos futuros y priorizar acciones para cerrar brechas; funcionan como un puente entre los resultados del CSF y la realidad operativa de la organización, facilitando la comunicación con los interesados y la alineación con los objetivos estratégicos (National Institute of Standards and Technology, 2024).

Figura 3 Pasos para crear y utilizar un perfil organizacional de CSF

Según la información disponible en (National Institute of Standards and Technology, 2024).



Fuente: (National Institute of Standards and Technology, 2024)

El proceso recomendado incluye:

- Definir el alcance del perfil: documentar hechos y supuestos de base; puede abarcar toda la organización o áreas específicas (ej. sistemas financieros, respuesta a ransomware).
- Recopilar información: políticas, prioridades de gestión de riesgos, recursos, análisis de impacto al negocio (BIA), requisitos de ciberseguridad, estándares aplicados, prácticas y roles.
- Crear el perfil organizativo: seleccionar resultados del CSF relevantes, documentar información y considerar riesgos del perfil actual para planificar el perfil objetivo.
- Analizar brechas: realizar un gap análisis entre el perfil actual y el objetivo, y elaborar un plan de acción priorizado (ej. registro de riesgos, POA&M).
- Implementar y actualizar: ejecutar el plan de acción, monitorear avances y actualizar el perfil regularmente.

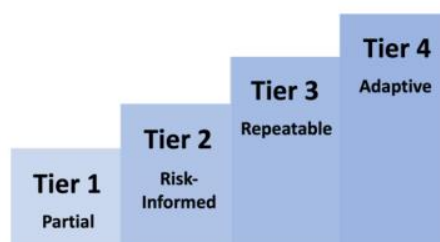
2.2.1.5 Tiers del CSF

Permiten a las organizaciones caracterizar el rigor de sus prácticas de gobernanza y gestión de riesgos de ciberseguridad; sirven como contexto para entender cómo la organización percibe los riesgos y qué procesos tiene en marcha para gestionarlos. (National Institute of Standards and Technology, 2024).

Los niveles reflejan una progresión:

- Tier 1-Parcial: respuestas informales y ad hoc.
- Tier 2 -Basado en riesgos (Risk-Informed): procesos definidos, aunque no siempre consistentes.
- Tier 3 -Repetible: procesos documentados y aplicados de manera sistemática.
- Tier 4 -Adaptativo: prácticas ágiles, informadas por riesgos y en mejora continua.

Figura 4 Niveles CSF para la gobernanza y gestión del riesgo de ciberseguridad



Fuente: (National Institute of Standards and Technology, 2024)

(*) Seleccionar un Tier ayuda a establecer el tono general de cómo la organización gestionará sus riesgos de ciberseguridad.

2.2.2 NIS2 Directive: requisitos, sectores críticos, obligaciones de reporte.

La Directiva NIS2 2022/2555 (European Union, 2022) establece un marco legal unificado para reforzar la ciberseguridad en 18 sectores críticos de la UE. Obliga a los Estados miembros a definir estrategias nacionales de ciberseguridad y a colaborar con la Unión Europea en la reacción y aplicación transfronteriza. Desde su punto vista entiende la ciberseguridad como la protección de redes y sistemas de información, sus usuarios y las personas afectadas frente a incidentes y amenazas.

Dadas las condiciones que anteceden, NIS2 sustituye a NIS1 (2016/1148) y se presenta con una ampliación, nuevas contribuciones de reglas y el fortaleciendo de herramientas de supervisión; en nuestro caso es de interés los cambios saber que se le exige a los organismos de dirección y a las directivas de los estados miembros:

- Refuercen sus capacidades de ciberseguridad.
- Introduzcan medidas de gestión de riesgos y obligaciones de reporte para más sectores.
- Establezcan reglas de cooperación, intercambio de información, supervisión y aplicación.
- Adopten una estrategia nacional de ciberseguridad, incluyendo políticas de seguridad en la cadena de suministro, gestión de vulnerabilidades y programas de educación y concienciación.
- Mantengan y actualicen una lista de operadores de servicios esenciales, asegurando su cumplimiento con los requisitos de la directiva.

En referencia a lo anterior a Directiva NIS2 con la directiva (UE) 2022/2555 (European Union, 2022), también amplió su alcance con la inclusión de nuevos sectores esenciales e importantes, reforzando las obligaciones de seguridad, la notificación de incidentes y la responsabilidad directa del órgano de dirección, según la directiva hay 18 sectores clasificados como críticos para ciberseguridad y resiliencia. Estos sectores se dividen en dos categorías:

Sectores esenciales: se definen como los sectores vitales y fundamentales para la seguridad nacional y las funciones sociales, garantizan la continuidad y la seguridad de los servicios esenciales que sustentan la vida cotidiana y la estabilidad económica. abarcan la energía, el transporte, la banca, la sanidad, las infraestructuras digitales y la administración pública, entre otros.

Sectores importantes: son sectores que apoyan la continuidad de servicios más susceptibles a riesgos de la cadena de suministro, digitales o sectoriales. Están integrados por: servicios postales y de mensajería, gestión de residuos, industria química, producción, transformación y distribución de alimentos, fabricación, proveedores digitales, investigación, producción y distribución de medicamentos esenciales y productos sanitarios

Tal como se ha visto si bien la tecnología es un denominador común, se reconoce que la resiliencia cibernética no depende únicamente de controles técnicos, sino también de las personas, sectores y organizaciones que toman de decisiones, estos cambios de la cultura de ciberdefensa en la investigación de nuestro modelo es un hecho inevitable porque el factor humano en el centro en los ecosistemas ha superado los marcos, políticas y herramientas de detección o defensa conocidas. Con las actualizaciones detalladas se aprecia la demanda de asumir un nuevo comportamiento general de las personas que están en todos los espacios públicos y privados en una capa de defensa activa, resiliente, medible y consiente de la realidad.

De igual manera la directiva (UE) 2022/2555 (European Union, 2022), enuncia que los proveedores de servicios gestionados (MSP) y las empresas de TI, clasificados como proveedores digitales, se enfrentan a nuevas e importantes responsabilidades:

- Se les exige que mejoren sus medidas de ciberseguridad y garanticen el cumplimiento de una normativa más estricta que incluye la aplicación de prácticas de seguridad sólidas.
- La realización periódica de riesgo evaluaciones y notificando los incidentes con prontitud.

- Son responsables de cualquier fallo o laguna en sus servicios que provoque brechas de ciberseguridad en los sistemas de sus clientes.
- Deben invertir en tecnologías avanzadas y formación para cumplir los requisitos de la directiva. la adopción de sofisticadas herramientas de supervisión, la mejora del incidente y asegurarse de que su personal está al tanto de las últimas prácticas de ciberseguridad.

2.2.2.1 Auditorías requeridas por la Directiva NIS 2

En este contenido, se delimita la clasificación las auditorias de la directiva (European Union, 2022) con su propósito y alcance:

- Auditoría de Cumplimiento Normativo: verifica políticas de seguridad, gobernanza, comunicación de incidentes y alineación con estándares como ISO/IEC 27001.
- Auditoría Técnica de Seguridad: evalúa infraestructura, firewalls, VPN, segmentación de red, pruebas de penetración, gestión de accesos y vulnerabilidades.
- Auditoría de Gestión de Riesgos: revisa identificación, mitigación y monitoreo de riesgos cibernéticos, incluyendo registros actualizados.
- Auditoría de Respuesta a Incidentes y Continuidad del Negocio: analiza planes de crisis, recuperación de datos, cumplimiento de plazos de notificación y efectividad mediante simulaciones.
- Auditoría de Proveedores y Terceras Partes: asegura que contratos incluyan cláusulas de seguridad, cumplimiento de estándares y monitoreo periódico de terceros.
- Auditorías Periódicas y Ad-hoc: realizadas regularmente según el perfil de riesgo o tras eventos significativos como incidentes de ciberseguridad.

2.2.2.2 Requisitos básicos de cumplimiento de NIS2 que toda entidad debe cumplir

Tomando como referencia la directiva (European Union, 2022), el cumplimiento de la normativa NIS2 no se trata de cumplir formalmente con requisitos; se trata de demostrar una cultura de seguridad madura; hay que tener en cuenta que la responsabilidad llega hasta la alta dirección: ahora la dirección ejecutiva es legalmente responsable de garantizar la gobernanza de riesgos, un cambio que exige una mayor concienciación que va más allá de los departamentos de TI. (Ver Tabla 2 Requisitos de la directiva NIS2).

2.2.2.3 Análisis de brechas NIS 2 (medidas de gestión de riesgos de ciberseguridad)

Esta es la hoja de ruta diseñada que ayuda a las organizaciones a comprender y aplicar la Directiva sobre redes y sistemas de información (NIS 2); actualizada ofrece información detallada sobre los requisitos de ciberseguridad ampliados, las estrategias de cumplimiento y las mejores prácticas del sector para reforzar su resistencia y salvaguardar las infraestructuras críticas frente a las ciberamenazas en evolución, garantizando la alineación con el nuevo marco normativo. (Ver Tabla 3 Plantilla de auditoría de brechas para la auditoría de cumplimiento de NIS 2).

2.2.3 Definiciones de Ciberseguridad desde diferentes ámbitos

La ciberseguridad definida en el artículo 2, punto 1, del Reglamento (UE) 2019/881; - Definición según el artículo 6 de la Directiva (UE) 2022/2555 (Directiva NIS2) "ciberseguridad": las actividades necesarias para proteger las redes y los sistemas de información, a los usuarios de dichos sistemas y a otras personas afectadas por las ciberamenazas.

De igual manera, López Díaz, Aguirre Ochoa & Navarrete Soriano (2024) apoya un punto de vista en la protección de datos personales, activos informáticos y seguridad social en contextos globales; señalando que la ciberseguridad es un concepto derivado de la seguridad de la información que busca proteger la confidencialidad, integridad y disponibilidad de datos frente a riesgos y amenazas en un mundo interconectado.

Pacheco (2023), propone un enfoque con una visión integral que conecta perspectivas técnicas y sociales, destacando la necesidad de cooperación multisectorial, para la ciberseguridad es un campo con divergencias entre academia, industria y comunidad técnica, pero que puede integrarse mediante un enfoque sociotécnico que permita una gobernanza multisectorial sostenible.

Lagos Melo (2024), plantea una relación con transformación digital y resiliencia entendiendo la ciberseguridad como un componente crítico de la transformación digital, vinculada a la gobernabilidad, resiliencia organizacional y capacidades dinámicas de las empresas. Su perspectiva se articula con la gestión de la ciberseguridad del marco NIST y NIS2 con la ambidiestralidad organizacional en su capacidad de adaptarse y ser resiliente en la adaptación IT.

2.2.4 NIST SP 800-53

Es un catálogo de controles de seguridad y privacidad diseñado para proteger sistemas de información, operaciones, activos y personas frente a amenazas como ataques hostiles, errores humanos, desastres naturales y riesgos de privacidad frente a una gama de riesgo. (National Institute of Standards and Technology, 2020).

En referencia de los controles de NIS SP800-53 (National Institute of Standards and Technology, 2020), sugiere que son flexibles y personalizables, y forman parte de un proceso integral de gestión de riesgos. En consecuencia, responden a requisitos legales, regulatorios y organizacionales, abordando la seguridad y la privacidad desde dos perspectivas funcional: proporciona mecanismos eficaces de para protección y en garantía: otorga un nivel de confianza para que cada mecanismo cumpla su propósito.

(National Institute of Standards and Technology, 2020) describe que las familias de los controles NIST 800-53 contiene más de 1000 controles, están organizados en 20 familias, cada una de las cuales cubre un aspecto específico de la ciberseguridad y la protección de datos, con el fin de simplificar el proceso de selección y especificación de controles de seguridad y protección de datos. (Ver la Tabla 4 Controles NIST 800-53), se enumeran las 20 familias de controles NIST 800-53 con su identificación de dos dígitos y proporciona un enfoque analítico de los controles.

En relación a lo último la autora , proyecta para su investigación ¿cuál sería el beneficio de concebir un catálogo de controles humanizados de ciberseguridad?, además de aportar una visión integral que transforma controles complejos en elementos traducibles para directivos, auditores y equipos no técnicos; ayuda a las organizaciones a responder y apropiarse con preguntas sencillas y un lenguaje común de su ciberseguridad para las auditorías en identificación de brechas, la medición de la madurez organizacional y la implementación de planes de mejora continua sobre, algunas interrogantes pueden ser sobre: activos críticos deben protegerse, nivel actual de cumplimiento normativo, nivel de exposición de la organización frente a los riesgos de ciberseguridad, los controles con brechas o mejoras, colaboradores preparados para identificar y responder a amenazas, impacto de los riesgos cibernéticos sobre el negocio y la operación, necesidades de las inversiones en ciberseguridad, resultados medibles en la capacidad para detectar, responder y recuperarse de un incidente, entre otros.

2.2.5 Humanización de métricas

Mendívil Caldentey, Sanz Urquijo y Gutiérrez Almazor (2022), en su trabajo titulado “Formación y concienciación en ciberseguridad basada en competencias: una revisión sistemática”, plantean que la humanización de las métricas se logra mediante la incorporación de indicadores que midan la concienciación y formación del personal no técnico; emplea la investigación de la literatura especializada, el uso de modelos de competencias en el desarrollo de programas de capacitación y sensibilización en ciberseguridad dirigidos a personal no especializado en TIC de empresas y organizaciones.

Su objetivo es explorar el grado de madurez y las principales características de la capacitación y la sensibilización en ciberseguridad basadas en competencias.

De manera análoga (Saltzer y Schroeder, 1975) afirmaron que "en la medida en que la imagen mental que el usuario tiene de las medidas de protección coincida con los mecanismos que debe utilizar, se minimizarán los errores"; este enfoque es viable si las empresas y organizaciones implementan iniciativas nuevas y eficaces en el ámbito de la formación y la concienciación sobre ciberseguridad, especialmente para el personal no especializado en TIC e iniciativas que puedan adaptarse al continuo desarrollo de las tecnologías y los procesos.

Considerando el precedente anterior, hay que destacar que la humanización de métricas no busca reemplazar o cuestionar el rigor técnico y cumplimiento de las normativas y metodologías de la ciberseguridad, están concebidas para facilitar que la información técnica llegue traducida a todas las personas que necesitan comprender su significado, impacto, consecuencias, comunicación; así como, las acciones preventivas y reactivas que conlleva asumir su rol participativo y activo en la protección, gobernanza, auditorías y mejorar continuas en la organización.

2.2.5.1 Comparación entre NIST CSF 2.0, Ley 21.663 y NIS2 frente a la humanización de métricas en ciberseguridad

Las contradicciones y limitaciones de los tres marcos citados son que coinciden en la necesidad de fortalecer la gobernanza (reglas, procesos y comportamientos) y la resiliencia organizacional para (anticipar, resistir, recuperarse y adaptarse a incidentes o ciberataques), pero son divergentes en la atención y la incorporación del factor humano en la gestión integral de la ciberseguridad.

Los marcos NIST CSF y NIS2 lo mencionan como atención a la cultura digital y la capacitación del personal y la Ley 21.663 omite los factores humanos ya que está dirigida al plano normativo, de cumplimiento y sancionatorio, el modelo propuesto expone un planteamiento que integra indicadores técnicos y humanizados en un sistema de comunicación ejecutiva amigable para reducir la brecha que transforma métricas complejas en información descifrable para los directorios y las gerencias.

(Ver Tabla 5 Comparación entre NIST CSF 2.0, Ley 21.663 y NIS2 frente a la humanización de métricas en ciberseguridad).

2.2.6 Ciberseguridad con la ISO 27032

Dada la norma ISO/IEC 27032:2012 (International Organization for Standardization, 2012), se establecen las directrices para la gestión integral de la ciberseguridad, esto significa que establece los lineamientos para la protección de los entornos digitales frente a amenazas emergentes. Con su enfoque integral esta norma aborda la interacción entre seguridad de la información, seguridad de las redes, seguridad de Internet y protección de infraestructuras críticas y seguridad de las aplicaciones.

En lo académico y profesional, la ISO 27032 es considerada una referencia clave para la gobernanza de la ciberseguridad porque promueve la cooperación entre múltiples actores: gobiernos, sector privado, usuarios finales y proveedores de servicios. Así como, su aplicación para definir en las organizaciones responsabilidades claras, establecer métricas de cumplimiento y fortalecer la resiliencia digital frente a ciberamenazas cada vez más sofisticadas.

2.2.7 Chile en Informe del Índice de Ciberseguridad Global de la UIT

En el Global Cybersecurity Index 2024 de la Unión Internacional de Telecomunicaciones (UIT), Chile aparece en un nivel intermedio de madurez en ciberseguridad, destacando avances en el ámbito legal y organizacional gracias a la creación de la Agencia Nacional de Ciberseguridad y la existencia de un CSIRT gubernamental, pero con brechas en capacidades técnicas, formación de talento especializado y protección de infraestructuras críticas, lo que lo ubica en un grupo de países con compromisos relevantes pero aún en desarrollo frente a los líderes globales (International Telecommunication Union, 2024).

En competitividad Internacional y relevancia regional Chile se encuentra en un grupo intermedio, es visto como un país en desarrollo en ciberseguridad, lo que puede afectar su posición en contratos internacionales que exigen cumplimiento avanzado. En este marco, se puede indicar que Chile ha desarrollado una estrategia nacional de ciberseguridad y planes de acción por medio de una estructura organizacional con la Agencia Nacional de Ciberseguridad y el CSIRT de Gobierno, que coordinan incidentes y políticas públicas y una legislación en ciberseguridad y protección de datos alineadas con estándares internacionales; que no la exime de las debilidades o brechas para consolidar sus equipos sectoriales de respuesta a incidentes (CIRTs) en las industrias críticas.

2.2.8 Auditorías de Ciberseguridad

Las auditorías de ciberseguridad se han consolidado como un mecanismo esencial para garantizar la resiliencia digital de las organizaciones. Según INCIBE (2025), estas auditorías permiten detectar fallos en sistemas y redes; por lo cual se debe revisar y evaluar cómo se protegen los equipos, sistemas y datos, detectando fallos de seguridad informática y proporcionando información útil sobre la efectividad de las medidas implementadas.

Mientras que Sabillón y Cano (2019) destacan su valor estratégico para medir la madurez y preparación frente a amenazas; infieren que es un proceso que permite evaluar la seguridad, madurez y preparación de una organización o nación frente a amenazas cibernéticas, mediante la aplicación de modelos como el Cybersecurity Audit Model (CSAM).

En un plano más técnico, EsGeeks (2024) subraya que las auditorías constituyen un análisis integral que va más allá de las pruebas de penetración, apoyándose en estándares internacionales como ISO/IEC 27001; debería ser una evaluación exhaustiva y metódica de un sistema de información, cuyo objetivo es identificar vulnerabilidades y riesgos potenciales.

Considerando los conceptos previos se puede afirmar que las auditorías de ciberseguridad son procesos fundamentales para evaluar, fortalecer y mantener la seguridad de la información y los activos digitales en una organización.

2.2.9 Auditorías norma ISO 27001

(International Organization for Standardization, 2022), denomina ISO 27001 como una guía internacional para auditorías de sistemas de gestión establece las directrices para la planificación, ejecución y seguimiento de auditorías de sistemas de gestión, incluyendo

aquellas orientadas a la ciberseguridad cuando se aplican a normas específicas como ISO/IEC 27001 o ISO/IEC 27032. Su ámbito de acción incluye:

- Define principios de auditoría, gestión de programas de auditoría y competencias de los auditores.
- Garantiza que las evaluaciones sean objetivas, sistemáticas y basadas en evidencia verificable.
- Proporciona el marco metodológico para evaluar la eficacia de los controles, identificar brechas de cumplimiento y recomendar acciones de mejora continua.
- Instrumento clave para asegurar la resiliencia digital y el cumplimiento normativo internacional.
- Asegura la resiliencia organizacional y el cumplimiento normativo internacional.
- Diferencia las auditorías internas y externas en su propósito y alcance, pero ambas deben regirse por los mismos principios de objetividad, sistematicidad y evidencia verificable, a continuación, se describe su alcance:
- Auditoría interna: se efectúa dentro de la propia organización para evaluar la eficacia de los sistemas de gestión, verificar el cumplimiento de políticas internas y detectar áreas de mejora continua; la norma establece que estas auditorías deben ser planificadas como parte del programa de auditoría y ejecutadas por personal competente, garantizando independencia respecto de las actividades auditadas.
- Auditoría externa: es llevada a cabo por entidades independientes, como organismos certificadores o consultoras, y tiene como objetivo validar el cumplimiento de normas internacionales. Con la información previa se puede señalar que, aunque las auditorías de ciberseguridad (INCIBE, Sabillón & Cano, EsGeeks) y la norma ISO 27001 aportan metodologías sólidas para evaluar controles, cumplimiento y madurez organizacional, existe una poca visibilidad o desarrollo respecto al interés por la humanización de las métricas; se ha concebido desde un punto de vista técnico, normativo y procedimental y se ha dejado en segundo plano la dimensión social que incluye la conducta y cultura del usuario en la organización. La consecuencia inevitable es un tecnicismo donde las auditorías comunican sus resultados en un lenguaje altamente especializado y se suma las limitaciones de discernimiento de los directorios y gerencias sin formación técnica;

entonces, hay que considerar dentro de la mejora continua innovar con una visión más cercana que incluya métricas humanizadas.

2.2.10 Metodología COBIT

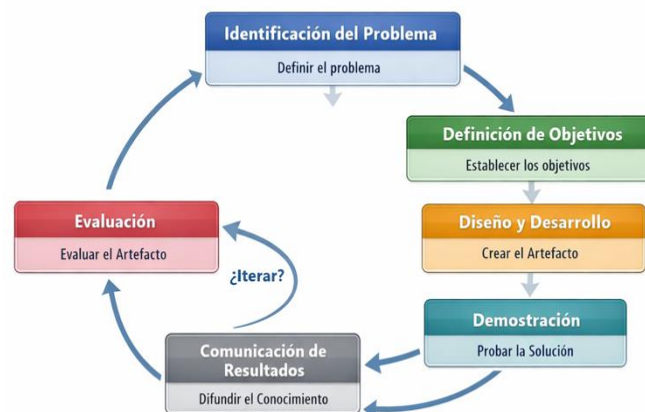
El marco COBIT (Control Objectives for Information and Related Technologies), desarrollado por ISACA, es un referente internacional para la gobernanza y gestión IT, su finalidad es alinear los objetivos de TI con los de la organización, establecer un sistema sólido de control y auditoría, y garantizar que la tecnología aporte valor mientras se gestionan riesgos y se cumple con las normativas vigentes (ISACA, 2019).

En el contexto de la investigación, COBIT complementa los marcos técnicos como NIST CSF y regulatorios como NIS2 en la dimensión de gobernanza corporativa (madurez organizacional y responsabilidad ejecutiva); con controles operativos-técnicos, visión de proceso, gobierno y auditoría y para NIS2 refuerza las obligaciones de resiliencia y responsabilidad directiva.

2.2.11 Metodología Design Science Research (DSR)

Design Science Research (DSR) es una metodología de investigación aplicada que busca crear, diseñar y evaluar artefactos como modelos, métodos, sistemas o herramientas para resolver problemas reales mediante conocimiento científico y diseño iterativo. Según Hevner, March, Park y Ram (2004), este enfoque combina el rigor académico con la relevancia de utilidad práctica, generando soluciones innovadoras y aportando nuevo conocimiento teórico sobre su efectividad.

Figura 5 Diagrama Proceso Design Science Research (DSR)



Fuente: Hevner, A. R., March, S. T., Park, J., & Ram, S. (2004)

2.3 BASES LEGALES DE LA INVESTIGACIÓN

2.3.1 Ley N°21.663/2024 Ley Marco de Ciberseguridad en Chile.

Ley N°21.663 (Gobierno de Chile, 2024).es el primer marco normativo integral de Chile para coordinar acciones de protección de datos y seguridad digital, se promulgo en marzo y publicada en abril de 2024, establece la creación de la Agencia Nacional de Ciberseguridad (ANCI) como organismo rector, responsable de dictar protocolos, coordinar equipos CSIRT, administrar el Registro Nacional de Incidentes y asesorar al Ejecutivo.

Su misión es garantizar la confidencialidad, integridad y disponibilidad de la información crítica, estableciendo principios de gobernanza, control de daños, cooperación interinstitucional y responsabilidad ejecutiva. Así mismo, establece las obligaciones de cumplimiento para organismos públicos y privados que presten servicios esenciales, regula auditorías de seguridad y examina las sanciones en caso de infracciones, alineándose con estándares internacionales como NIS2 y NIST CSF.

2.3.2 Ley N°21.459/2022 sobre Delitos Informáticos en Chile

Esta iniciativa moderniza el marco penal en materia de ciberseguridad, derogando la antigua Ley N°19.223 (Gobierno de Chile, 2024) y alineándose con el Convenio de Budapest. Su objetivo es tipificar nuevas conductas ilícitas en el ámbito digital, como el acceso indebido, la interceptación de comunicaciones, la manipulación de datos, el fraude informático y el abuso de dispositivos, por otro lado, se establecer sanciones más severas y responsabilidad penal para empresas.

La norma contempla penas de presidio y multas, regula la preservación de datos informáticos en investigaciones, y otorga legitimación activa al Ministerio del Interior en casos que afecten servicios de utilidad pública. Asimismo, incorpora agravantes como el abuso de confianza o la afectación a menores, y atenuantes como la cooperación eficaz. En conjunto, esta ley fortalece la capacidad del Estado para perseguir ciberdelitos y complementa la Ley N°21.663/2024, que regula la gobernanza y protección de datos, creando un ecosistema normativo robusto frente a amenazas digitales.

2.3.3 Normativas sectoriales en Chile

Las siguientes normativas complementan la Ley Marco de Ciberseguridad y las leyes de delitos informáticos (Gobierno de Chile, 2024), para definir los requisitos y exigencias técnicas específicas según el ámbito regulado. En general, su propósito es garantizar la seguridad, transparencia y resiliencia en sectores financieros, telecomunicaciones y servicios digitales, alineándose con estándares internacionales como NIS2 y NIST CSF.

- Comisión para el Mercado Financiero (CMF): su misión es avalar la estabilidad del sistema financiero y la confianza de los usuarios, en la prevención de crisis derivadas de incidentes cibernéticos; mediante las Normas RAN y la NCG 461., que forman los lineamientos para continuidad operacional, gestión de riesgos tecnológicos y ciberseguridad en bancos y entidades supervisadas. Adicionalmente, la Guía ESG incorpora criterios ambientales, sociales y de gobernanza, incluyendo la protección de datos y resiliencia digital.
- Telecomunicaciones SUBTEL: hace referencia a la Subsecretaría de Telecomunicaciones (SUBTEL) dicta normativas técnicas que regulan la seguridad de redes, la protección de infraestructura crítica y la continuidad de servicios esenciales de telecomunicaciones; su propósito es asegurar la disponibilidad de servicios de comunicación frente a incidentes cibernéticos o fallas técnicas. La importancia radica en que las telecomunicaciones son un pilar de la economía digital y de la seguridad nacional.
- Superintendencias Sectoriales (Salud, Pensiones, Energía, etc.): las distintas superintendencias sectoriales emiten Normas de Carácter General (NCG) que exigen planes de seguridad de la información, auditorías periódicas y protocolos de respuesta a incidentes en sectores críticos como salud, pensiones, electricidad y combustibles; Su propósito es garantizar la continuidad de servicios esenciales y la protección de datos sensibles.
- Fintech Ley N°21.521/2023 (Gobierno de Chile, 2023): regula las plataformas de financiamiento colectivo, intercambio de criptoactivos y servicios de pago, bajo supervisión de la CMF y exige medidas de ciberseguridad, protección de datos de clientes y gestión de riesgos tecnológicos, alineadas con estándares internacionales. Su propósito es fomentar la innovación financiera con seguridad y transparencia en el ecosistema digital financiero y protege a los usuarios frente a fraudes y vulnerabilidades.

2.3.4 Gobierno Corporativo y la importancia de la cultura de ciberseguridad. Rol del Directorio

En Chile el Gobierno Corporativo público y privado deben liderar la cultura de ciberseguridad, integrando la gestión de riesgos digitales en la estrategia corporativa, asegurando cumplimiento normativo y fomentando la concienciación organizacional. Esto convierte la ciberseguridad en un tema de responsabilidad fiduciaria y reputacional, con impacto directo en la sostenibilidad y confianza empresarial.

En Chile, el Directorio se ve afectado por diversas leyes y normativas:

- Ley N°21.663/2024 (Ley Marco de Ciberseguridad): establece la responsabilidad ejecutiva en la gobernanza de la seguridad digital y crea la ANCI como ente rector (Gobierno de Chile, 2024).
- Ley N°21.459/2022 (Delitos Informáticos): sanciona conductas ilícitas digitales y contempla responsabilidad penal de las empresas, lo que impacta directamente en la gestión corporativa (Gobierno de Chile, 2022).
- Normativas sectoriales de la CMF (NCG 461, Normas RAN, Guía ESG): obligan a los directorios de entidades financieras a implementar políticas de continuidad operacional, gestión de riesgos y ciberseguridad.
- Normativas de SUBTEL y superintendencias sectoriales: regulan la seguridad en telecomunicaciones, salud, pensiones y energía, imponiendo obligaciones de cumplimiento a los órganos de gobierno corporativo.
- Ley Fintech N°21.521/2023: exige a los directorios de empresas tecnológicas y financieras garantizar la protección de datos de clientes y la gestión de riesgos tecnológicos (Gobierno de Chile, 2023).

2.3.5 Aspectos legales futuros pendientes en el marco de ciberseguridad en Chile

El Marco de Ciberseguridad en Chile, consolidado con la Ley N°21.663/2024 (Gobierno de Chile, 2024) y complementado por la Ley N°21.459/2022 (Gobierno de Chile, 2022): y normativas sectoriales, aún presenta vacíos legales y pendientes futuros que deben ser abordados para lograr una regulación más robusta y alineada con estándares internacionales.

Entre los principales vacíos se encuentran:

- Protección de datos personales: aún falta una ley integral y actualizada que complemente la ciberseguridad con un marco fuerte de privacidad, similar al RGPD europeo.

- Regulación de inteligencia artificial y ciberseguridad en entornos críticos: no existen normas específicas que aborden riesgos derivados del uso de IA en procesos industriales, financieros o gubernamentales.
- Ciberseguridad en PYMEs y sectores no regulados: la normativa actual se centra en servicios esenciales y operadores críticos, dejando fuera a gran parte del tejido empresarial que también enfrenta riesgos.
- Responsabilidad civil y seguros cibernéticos: aún falta un marco que establezca compensaciones, seguros obligatorios o mecanismos de reparación frente a incidentes que afecten directamente a los usuarios y clientes.
- Cooperación internacional y armonización normativa: Chile está adosado con el Convenio de Budapest y los estándares como NIS2 y NIST CSF, sin embargo, aún requiere acuerdos bilaterales y regionales para enfrentar amenazas digitales de carácter transfronterizo.

2.4 CONCLUSIÓN

Chile ha avanzado en la madurez de su marco regulatorio como una mirada general del problema de la ciberseguridad, no obstante, persisten vacíos metodológicos, tecnológicos y humanos para el desarrollo asertivo de proyectos y gobiernos internos en las organizaciones. Al explorar se denota la ausencia de una ley integral de protección de datos personales, la falta de regulación específica sobre inteligencia artificial, la limitada inclusión de PYMEs en el marco normativo, la inexistencia de seguros cibernéticos obligatorios y la necesidad de fortalecer la cooperación internacional.

La complejidad de los nuevos ecosistemas de ciberseguridad y auditorías demandan de homologar el ecosistema normativo chileno hacia un enfoque proactivo y global, que incorpora las buenas prácticas de gobernanza y gestión de riesgos ya probados en la Unión Europea y Estados Unidos en su contexto local. En este proceso, las organizaciones no sólo adoptan controles técnicos, sino que también construyen una cultura de ciberseguridad, lo que incrementa su competitividad, genera confianza y potencia su valor en el mercado.

En otro ámbito el (Kevin Mitnick ,2022) experto en seguridad informática indica que el eslabón más débil de la cadena de ciberseguridad es el ser humano; entonces, incorporar la humanización de las métricas tiene sentido para resultados claves más allá de controles técnicos, hay incorporar la traducción y simplificación de la métricas enfocado a los factores

humanos que promuevan la adopción y la mejora continua como la conciencia de los usuarios, la capacitación, la resiliencia organizacional y la confianza social; De ese modo, los indicadores expresaran tanto la eficacia tecnológica como el impacto humano, fortaleciendo la gobernanza corporativa y la capacidad de respuesta frente a amenazas digitales.

En conclusión, luego de revisar los marcos y autores se evidencia y se justifica la necesidad de adaptar e incluir los marcos internacionales al contexto chileno para fortalecer la gobernanza y garantizar el cumplimiento normativo; adicionalmente, a nivel de la literatura hay un vacío con escasa información y visibilidad sobre la integración de métricas humanizadas y modelos de ciberseguridad. Estas insuficiencias o puntos débiles es lo que precisa abordar la propuesta de un modelo integrado de auditoría y métricas humanizadas, que sistematice la relación y entendimiento entre (indicadores técnicos -regulaciones -información estratégica y acción) fortaleciendo la resiliencia y la toma de decisiones en las organizaciones en Chile.

3 OBJETIVOS CONCRETOS Y METODOLOGÍA DE TRABAJO

Este bloque es el puente metodológico y conceptual que conecta entre el estudio del dominio y la aportación específica a realizar de este trabajo, a continuación, los objetivos generales y específicos:

3.1 Objetivo general

Diseñar y validar un modelo integral de auditoría de ciberseguridad basado en métricas de cumplimiento humanizadas, alineado con los marcos NIST CSF 2.0, NIST SP 800-53 y la Directiva NIS2, adaptado al contexto normativo y organizacional de Chile, que permita a las organizaciones evaluar, medir y reportar su nivel de madurez en ciberseguridad mediante indicadores clave (KPIs/KRIs) que integren dimensiones técnicas como humanas, apoyados en herramientas tecnológicas de visualización ejecutiva desarrolladas en Excel con un Cuadro de Mando.

3.2 Objetivos específicos

1. Analizar el marco normativo actual de ciberseguridad en Chile y su relación con los estándares internacionales NIST CSF y la directiva NIS2 para establecer el contexto de aplicación y detectar oportunidades de incorporar métricas humanizadas.

2. Desarrollar una matriz de alineación (cross-walk) en formato tabular (Excel) que integre las funciones, categorías y subcategorías del NIST CSF con las obligaciones de gestión, gobierno y control definidas en NIS2 (dimensiones organizaciones-humanas)
3. Definir un catálogo estructurado de indicadores Clave de Desempeño (KPIs) e indicadores Clave de Riesgo (KRIs) diseñados para medir el nivel de implementación, madurez y eficacia de los controles técnicos y los factores humanos (concienciación, cultura digital, resiliencia).
4. Construir un Cuadro de Mando Integral utilizando Microsoft Excel que consuma los datos de la matriz de auditoría para visualizar el nivel de cumplimiento por áreas de control.
5. Validar el modelo propuesto mediante la aplicación de datos y registros de seguridad en un piloto propuesto en la organización Modinger Hermanos S.A. (Cecinas Llanquihue), con el fin de demostrar su aplicabilidad práctica y evaluar la integración de métricas humanizadas para generar recomendaciones de mejora.

Para cumplir los objetivos propuestos, y dado que este TFE se enmarca dentro de la categoría "Tipo 3 Desarrollo de metodología", se plantea un modelo estructurado de auditoría y métricas humanizadas soportado por herramientas tecnológicas para su evaluación.

3.3 Fases design science research (DSR)

El desarrollo de este trabajo sigue una metodología estructurada en cinco fases secuenciales e iterativas, orientada al diseño y validación de un modelo aplicable. La metodología se inscribe en el paradigma del Design Science Research (DSR), que combina investigación aplicada con la construcción de artefactos que resuelven problemas reales, a continuación, descripción de las fases:

3.3.1 Fase 1: Revisión y análisis documental

Se realizará una revisión sistemática de la literatura científica, normativa y técnica relevante para el trabajo para comprender el ecosistema normativo antes de diseñar los controles. Las fuentes incluirán: publicaciones del NIST (mapeo las 6 funciones, 22 categorías y 106 subcategorías), 10 artículos de gestión de riesgos de NIS2 (Art. 21), de la Directiva NIS2, los artículos 3 al 22 de la Ley N°21.663 y los plazos de implementación ANCI y su reglamentación, informes de organismos internacionales (BID, OEA, ENISA, Interpol) y artículos académicos sobre auditoría de ciberseguridad y métricas de cumplimiento humanizadas.

3.3.2 Fase 2: Diseño del catálogo de controles integrado

Se construirá una matriz de alineación cruzada (cross-walk) donde se comparan los controles NIST CSF 2.0 y las obligaciones NIS2 que son estándares internacionales con la normativa local Ley 21.663; para la revisión se han considerado los principales grupos de control o funciones del NIST CSF (Identificar, Proteger, Detectar, Responder, Recuperar, Gobernar) señalando las correspondencias de qué artículos de NIS2 y de la Ley 21.663 se relacionan. De esta manera se construyen los 20 indicadores más relevantes para la autora.

3.3.3 Fase 3: Diseño del sistema de métricas KPI/KRI

Se definen el sistema de métricas de desempeño (KPIs) y de riesgo (KRIs) por dominio que se utilizarán, convirtiendo los marcos normativos internacionales y la Ley N°21.663 con 20 *indicadores* (técnicos-humanizados) específicos, comprensibles y medibles. Cada indicador incluye nombre comprensible, fórmula, fuente de datos, frecuencia de medición y umbrales RAG.

3.3.4 Fase 4: Recolección de Datos y medición Inicial y análisis de Brechas y Priorización

Se plantea el esquema base para la línea base para una organización simulada; se recopilan evidencias y se calculan los valores reales de cada KPI/KRI definidos; la idea es saber “dónde estamos” antes de formular mejoras.

Adicionalmente, luego de tener de la línea base se busca identificar las brechas críticas para proyectar un plan de acción priorizado para cerrarlas según la urgencia.

3.3.5 Fase 5: Implementación tableros de mando

Se materializa la creación de la visualización ejecutiva, la creación de tres vistas de tablero de mando que comunica el estado global de la ciberseguridad traducida más allá de lo técnico, la situación del cumplimiento normativo Ley 21.663 y vista para el directorio que agrupada por dominio con las preguntas del estado de la seguridad y las acciones recomendadas para su toma de decisiones.

Para las vistas, seleccionaron los siguientes indicadores por dominio:

- Gobernar (GV): estrategia aprobada GV-KPI-01, presupuesto dedicado GV-KPI-01 y madurez gobernanza GV-KRI-02.

- Identificar (ID): inventario de activos ID-KPI-01, riesgo de proveedores ID-KPI-04 y vulnerabilidades críticas sin resolver ID-KRI-01.
- Proteger (PR): capacitación del personal PR-KPI-01, MFA activa PR-KPI-02 y cifrado de datos PR-KPI-05.
- Detectar (DE): velocidad de detección/MTTD DE-KPI-02, cobertura de monitoreo DE-KPI-04 y dwell time DE-KRI-03. RS-KPI-04,
- Responder (RS): notificación en plazo ANCI RS-KPI-02, contención/MTTC RS-KPI-03, simulacros, Recuperar (RC) e incidentes no reportados RS-KRI-03.
- Recuperar (RC): recuperación en RTO, MTTR RC-KRI-01, plan BCP/DRP vigente RC-KPI-03 y lecciones aprendidas RC-KPI-04.

Figura 6 Bocetos de vista idea de tablero de mando



Fuente: Elaboración propia

3.3.6 Fase 6: Validación mediante caso de estudio

Con la restricción de no divulgación de la información del *Security Operations Center* (SOC), la autora diseño un instrumento de recolección de información que será completado por encargo de la seguridad de Modinger Hermanos S.A. (Cecinas Llanquihue), la fuentes de datos planteadas provienen de registros internos del SOC, documentación de continuidad (BCP/DRP) y reportes financieros entre otras: estos datos operativos y reales serán validados en el cuadro de mando del modelo generando los resultados de los KPI's y KRI's seleccionados y los tableros de mando. (Ver Tabla 16 Instrumento de Recolección de Información del Modelo).

Figura 7 Planificación metodológica del trabajo de investigación



Fuente: Elaboración propia

4 DESARROLLO ESPECÍFICO DE LA CONTRIBUCIÓN

En este apartado se expone el aporte de este trabajo de investigación que propone un modelo de auditoría de ciberseguridad que incorpora metodología de concepto para el diseño de métricas humanizadas de cumplimiento, se transforma la sistematización de indicadores técnicos en preguntas o afirmaciones comprensibles para todos los niveles de la organización, conservando el rigor técnico y su trazabilidad con los estándares internacionales NIST CSF 2.0 y la directiva NIS2 que complementan los vacíos del entorno legal chileno bajo la Ley N° 21.663.

La iniciativa de esta investigación busca reducir las brechas de información en el desarrollo del gobierno interno de ciberseguridad aplicado a las organizaciones que opera en Chile y los desafíos de interpretación de las métricas técnicas. No obstante, su arquitectura permite su adaptación a cualquier organización que incorpore y opere bajo los marcos de referencia fundamentados en NIST CFS 2.0 y NIS2 y entrega un instrumento para los responsables de seguridad y IT que emiten reportes ejecutivos a la alta gerencia.

4.1 Desarrollo de la metodología

4.1.1 Identificación de requisitos

La gestión de la ciberseguridad y normativas en las organizaciones a nivel internacional han progresado hacia una dimensión estratégica y humana que trasciende el ámbito técnico, para instituir la interconexión entre las decisiones de gobernanza, el cumplimiento normativo, métricas comprensibles y la justificación de inversiones en ciberseguridad.

Según Mendoza Schmitz (2024) en su enfoque de análisis político y jurídico de la Ley 21.663 plantea que, aunque la Ley Marco de Ciberseguridad representa un avance relevante en Chile, todavía persisten vacíos legales y una falta de madurez institucional que dificultan garantizar una protección efectiva en este ámbito. En este mismo orden de ideas, Bordachar Benoit (2023) destaca que, si bien la creación de la Agencia Nacional de Ciberseguridad posiciona a Chile como referente en Latinoamérica, aún están en la etapa inicial de implementación y fiscalización lo que limita todavía el impacto real de esta institución en la gestión de la ciberseguridad en las organizaciones.

Considerando, los antecedentes Chile va en rumbo las actualizaciones, pero le falta madurez, leyes y reglamentos en su legislación que deben ser complementados con los marcos internacionales NIST y NIS2, es válido incorporar, relacionar y adaptar marcos, modelos y metodologías dirigidas a estandarizar y conectar de formar útil y comprensible la información técnica a indicadores de ciberseguridad humanizados, medibles y verificables con (KPIs/KRIs) y herramientas de auditoría.

A continuación, se describen las obligaciones seleccionadas para el modelo para la Ley Marco de Ciberseguridad N°21.663:

- (Artículo 12) Título de la Obligación: implementación de controles técnicos mínimos de seguridad para garantizar la protección de sistemas críticos y la información sensible. Ej. Autenticación fuerte (MFA), Cifrado de la información y gestión de accesos.
- (Art. 3) Gobernanza de ciberseguridad: se exige a la organización tener una estrategia de ciberseguridad formalmente aprobada y un responsable designado (CISO o equivalente).
- (Art. 4) Gestión de activos e inventario: deben identificar y mantener actualizado el inventario de activos de información y sistemas críticos.
- (Art. 5) Evaluación continua de riesgos: se evaluar periódicamente sus riesgos de ciberseguridad y documentar los resultados.
- (Art. 6) Responsabilidad del directorio: el directorio debe involucrarse activamente en la gobernanza de la ciberseguridad y aprobar la política institucional.
- (Art. 7) Política de ciberseguridad: las organizaciones deben contar con una política de ciberseguridad documentada, aprobada y comunicada a todo el personal.
- (Art. 8) Presupuesto de ciberseguridad: asignar recursos financieros suficientes para implementar y mantener los controles de ciberseguridad.
- (Art. 9) Cumplimiento normativo y reporte al directorio: el directorio debe recibir reportes periódicos sobre el estado de ciberseguridad y el cumplimiento de la política.
- (Art. 10) Gestión de riesgos de tercero: deben evaluar los riesgos de ciberseguridad de los proveedores críticos y exigir cumplimiento en contratos.
- (Art. 11) Capacitación y concienciación: el personal debe recibir formación obligatoria y periódica en ciberseguridad, con registros verificables.
- (Art. 13) Pruebas de seguridad y auditorías técnicas: las organizaciones deben realizar pruebas periódicas de seguridad (pentesting) y auditorías técnicas.

- (Art. 14) Monitoreo continuo (SIEM/SOC): corresponde tener capacidad de monitoreo continuo de eventos de seguridad para detectar incidentes oportunamente.
- (Art. 15) Inteligencia de amenazas: obliga a las organizaciones a integrar inteligencia de amenazas en sus procesos de seguridad para anticipar riesgos emergentes.
- (Art. 16) Plan de respuesta a incidentes: se obliga a tener un plan de respuesta a incidentes documentado, probado y con roles asignados.
- (Art. 17) Gestión de incidentes y lecciones aprendidas: cada incidente debe ser gestionado formalmente, documentarse y generar lecciones aprendidas para la mejora continua.
- (Art. 18) Notificación de incidentes a la ANCI: los incidentes de ciberseguridad significativos deben notificarse a la ANCI dentro de las 72 horas de detección.
- (Art. 19) Contenido del reporte de incidente a ANCI: el reporte debe incluir descripción del incidente, sistemas afectados, acciones tomadas e impacto estimado.
- (Art. 20) Continuidad operacional y recuperación: se comprometen a contar con planes de continuidad de negocio (BCP) y recuperación ante desastres (DRP) probados.
- (Art. 21) Plan de continuidad de negocio: se exige que el BCP debe definir RTOs y RPOs para cada servicio crítico y ser validado periódicamente.
- (Art. 22) Mejora continua y ciclo PDCA de ciberseguridad: las organizaciones deben incorporar mejoras continuas basadas en los resultados de auditorías, incidentes y ejercicios.

Considerando los vacíos la Ley Marco de Ciberseguridad N°21.663 la Directiva NIS2 contribuye con un nivel de gobernanza más exigente en la responsabilidad directa del órgano de dirección en la supervisión de la ciberseguridad y en la aprobación de políticas y presupuestos, NIS2 amplía la obligación de la gestión de activos (Art. 4) al incluir la cadena de suministro, algo novedoso que eleva el estándar para Chile es que en el plan de continuidad de negocio (Art. 21), se incorpora la resiliencia de proveedores y la coordinación transfronteriza.

Por su parte, el NIST Cybersecurity Framework (CSF 2.0) coopera con su enfoque metodológico que traduce las obligaciones legales en funciones medibles y niveles de madurez y su marco práctico que permite operacionalizar las exigencias legales de la Ley 21.663 , en contraste con los artículos revisados NIST CSF complementa la gestión de activos (Art. 4) al vincularlos con funciones críticas de negocio, se emplaza en la asignación de recursos (Art. 8) hacia un modelo

de madurez progresiva (Tiers) y en el plan de continuidad (Art. 21) incorpora dentro de la función “Recover”, promoviendo la mejora continua y la resiliencia organizacional.

4.1.2 Descripción de la metodología

4.1.2.1 Identificación de Roles y Actores Implicados

La participación de los roles y actores recomendados son aquellos que participan en la ejecución de la auditoría y son los dueños de la información generada:

- Alta Dirección y Gobierno: Directorio, CISO (Chief Information Security Officer). y Auditor.
- Operación y Control: Responsables de TI, equipos de auditoría interna y áreas de cumplimiento.
- Terceros: Proveedores críticos de servicios.

Los artículos de la Ley 21.663 se organizan en Ver el detalle de los perfiles de los actores y su rol (ver tabla 6).

Tecnologías Implicadas

Para replicar un entorno de producción simulado, validar funcionamiento y desarrollar el dashboard del modelo de auditoría se seleccionaron las siguientes herramientas:

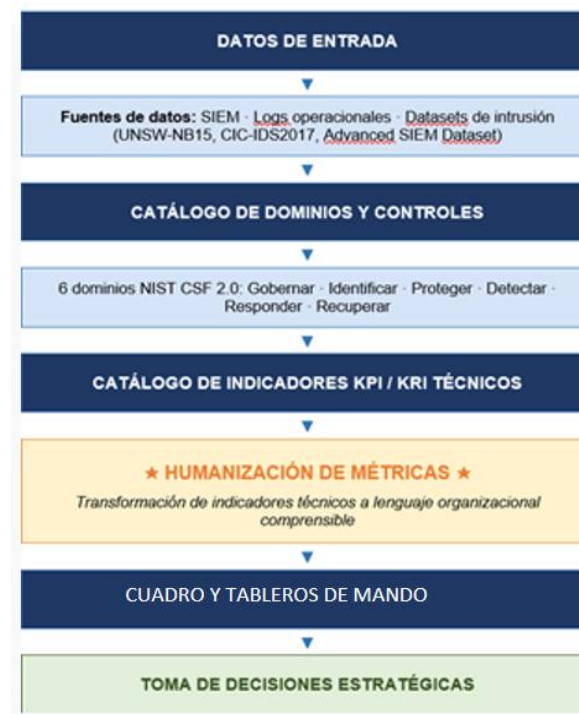
- Plataformas SOC para la monitorización, detección y respuesta temprana ante incidentes.
- Herramientas de inteligencia de negocios, con tableros ejecutivos, para la visualización dinámica de métricas (KPIs/KRIs) y reportes de estado.
- Microsoft Excel.

4.1.3 Fundamento Metodológico: Design Science Research (DSR)

Se aborda el paso a paso que interconecta la implementación desde la entrada de datos hasta la presentación ejecutiva del modelo de auditoría propuesto bajo el paradigma Design Science Research (DSR), se describe el desarrollo de sus fases y sus elementos con la metodología, su arquitectura y componentes que se aplicaran en el entorno organizacional:

Arquitectura del Modelo

Figura 8 Arquitectura del modelo flujo modelo de auditoría de ciberseguridad con métricas humanizadas



Fuente: Elaboración propia

Dominios de control

El modelo se organiza alrededor de la gestión de la ciberseguridad de seis dominios de control, propios de las seis funciones del NIST CSF 2.0, cada uno fue adaptado con una denominación humanizada que conecta la realidad de la organización con los artículos de la Ley 21.663; se incorpora una pregunta ejecutiva dirigida a la evaluación de la dirección acerca del estado de cumplimiento de la seguridad en la tabla 7 se visualiza la descripción de los dominios los artículos de la Ley 21.663 que agrupan las diferentes categorías según los objetivos normativos.

Guía de Metodología: Modelo de Auditoría de Ciberseguridad

El análisis cruzado y la auditoría de ciberseguridad, se fundamentan documentando los resultados en un archivo de Excel disponible en el repositorio <https://github.com/Oritapo/Unir>, las hojas de trabajo son: dominios de control NIST CSF 2.0 humanizados, catálogo de indicadores KPI / KRI métricas humanizadas, cuadro de mando

ejecutivo de ciberseguridad, alineación con ley marco de ciberseguridad n°21.663 Chile, plantilla de auditoría de brechas nivel de madurez, matriz de alineación cruzada (NIST CSF 2.0-NIS2- Ley 21.663).

Fase 1: Revisión y análisis documental

Se formula y se evalúa un lenguaje común antes de auditar cualquier control con un marco conceptual de las fuentes de información validado y se construye la definición humanizada y en contexto de uso homologado con la expresión técnica de los dominios de control de función NIST CSF 2.0.

- Gobernar (GV)= Gobierno y Estrategia Digital.
- Identificar (ID)= Conocer lo que Protegemos
- Proteger (PR)=Defensa Activa de la Organización
- Detectar (DE): Vigilancia y Alerta Temprana
- Responder (RS): Respuesta a incidentes
- Recuperar (RC): Resiliencia y continuidad Operacional

Igualmente, se apoya con un glosario de términos y siglas que orienten a los perfiles no técnicos como (CISO, directorios o usuarios) en la interpretación de la terminología.

Hojas de Excel: Dominios (ver tabla 7)

Fase 2: Diseño del catálogo de controles integrado

Se documentan dos matrices para establecer de donde nace cada control a auditar y con qué normas se asocia la fuente de documentación recomendada que pueden ser (políticas, actas o registros), en el caso de la matriz Ley 21663 se señalan los artículos los indicadores relacionados, su frecuencia, sanciones de cumplimiento y su estado; esta se actualiza manualmente en la columna de estado (Pendiente, Cumplido y En Proceso).

La matriz NIST_NIS2_Xwalk es un catálogo de controles de alineación cruzada (cross-walk) donde se comparan y se identifican la correspondencia de los controles del NIST CSF con los artículos de NIS2 y la ley chilena, para que cada control se transforme en un indicador medible se aplica una la escala y se documenta la brecha detectada donde se identifica el vacío normativo o de interpretación. Clasificación de nivel de alineación:

- Alto (control directo): el control del NIST tiene equivalente directo en NIS2 o la Ley 21663.

- Medio (parcial): se tienen coincidencias parciales o indirectas
- Bajo (brecha): existe una brecha o ausencia de correspondencia.

Hojas de Excel: Ley 21663 (ver tabla 8) y NIST_NIS2_Xwalk (ver tabla 9-10)

Fase 3: Diseño del sistema de métricas KPI/KRI

En esta fase se obtienen dos respuestas a través de los indicadores distribuidos en las categorías funcionales con los KPI (Key Performance Indicator) que miden qué tan bien está funcionando un control o proceso de ciberseguridad y responde ¿lo que se está haciendo bien?, de igual manera, con los KRI (Key Risk Indicator) se puede medir el nivel de exposición de la organización ante una amenaza o vulnerabilidad y responde: ¿qué tan expuestos están?

Corresponde adaptar la realidad de la auditoría en la escala de umbrales auditables:

- ÓPTIMO ($\geq 80\%$): control está implementado (funcionando dentro de los parámetros esperados).
- PRECAUCIÓN (50–79%): el control existe (pero presenta deficiencias que requieren atención).
- ALERTA ($< 50\%$): el control es insuficiente o inexistente (se requiere acción inmediata)

Se debe destacar, que cada indicador tiene una estructura normalizada que incluye: nombre humanizado, la pregunta hacia la directiva, la fórmula del indicador, las fuentes de datos, frecuencia de medición, y los umbrales del semáforo RAG.

Hoja de Excel: KPIs/KRIs (ver tablas 11 y 12)

Fase 4: Recolección de Datos y medición Inicial y análisis de Brechas y Priorización

Se analizan la situación de la normativa, se mide la madurez de los controles y el registro de brechas en la ciberseguridad, utilizando la matriz Auditoría Gap, con la escala de niveles de madurez del 1 a 5 para la evaluación estratégica de la gobernanza.

Clasificar el nivel de alineación, para reflejar el grado de desarrollo del control en la organización:

- 1=Inicial (sin procesos definidos)
- 2=Gestionado (prácticas básicas)
- 3=Definido (procesos documentados)
- 4=Cuantificado (medición continua)

- 5=Optimizado (mejora continua e innovación)

Se debe enfatizar, que el campo brecha GAP documenta y detecta el incumplimiento donde la organización cumple o no el requisito, para un plan de acción correctivo.

Hoja de Excel: Auditora de brechas (ver tabla 13)

Fase 5: Implementación del Tablero de Mando

Se diseñan las vistas de los tableros de mando con los resultados del método de semaforización con fórmulas probadas y vinculada a las hojas de dashboard y la Ley 21663.

Datos de interés en el monitoreo:

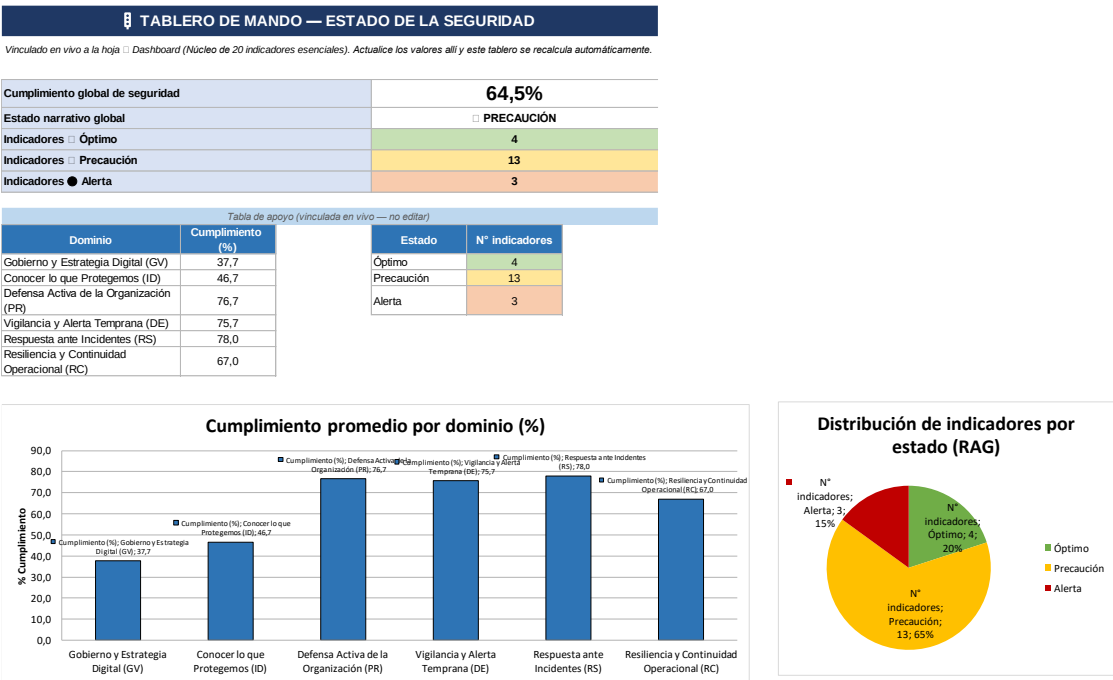
Tablero de seguridad: muestra un resumen ejecutivo global del porcentaje del estado de la seguridad de la organización, incluye: cumplimiento global de seguridad, gráficos de cumplimiento promedio por dominio (%) y la distribución de indicadores por estado (RAG).

Tablero de Cumplimiento: se consideró sólo el cumplimiento normativo de la Ley 21.663, se genera con el conteo del estado de los artículos y se relaciona con gráficos % de artículos cumplidos por dominio y estado de cumplimiento normativo Ley N°21.663.

Tablero Ejecutivo: esta la visita traducida de los indicadores técnicos, con las preguntas humanizada cualquier persona no técnica comprenderá el estado de la seguridad en los dominios y tendrá la recomendación de que hacer al respecto.

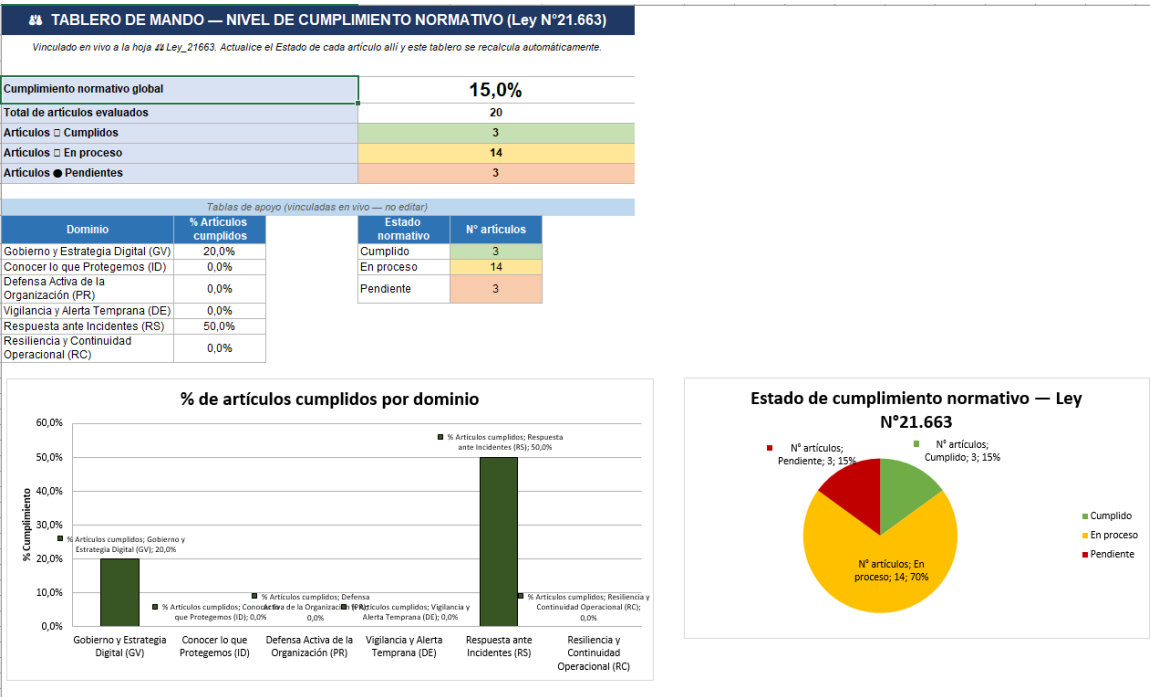
Hoja de Excel: Cuadro de mando ejecutivo de ciberseguridad (ver Tabla 14 Plantilla Cuadro de Mando Ejecutivo de Ciberseguridad) y las figuras 9, 10 y 11 de los tableros de mando con los resultados derivados del Dashboard.

Figura 9 Tablero de mando estado de la seguridad



Fuente: Elaboración propia

Figura 10 Tablero de mando nivel de cumplimiento normativo Ley 21.663



Fuente: Elaboración propia

Figura 11 Tablero ejecutivo Indicadores Humanizados

📌 TABLERO EJECUTIVO — INDICADORES HUMANIZADOS PARA EL DIRECTORIO				
Lectura ejecutiva del Núcleo de 20 indicadores esenciales, en lenguaje simple y sin siglas técnicas. Vinculado en vivo a la hoja ☐ Dashboard.				
Dominio	¿Qué nos preguntamos?	Resultado	Estado	¿Qué hacemos al respecto?
Gobierno y Estrategia Digital (GV)				
Gobierno y Estrategia Digital	¿Tenemos estrategia de ciberseguridad aprobada?	50%	⚠ PRECAUCIÓN	Revisar políticas pendientes de aprobación
Gobierno y Estrategia Digital	¿Tenemos presupuesto dedicado a seguridad?	8%	🔴 ALERTA	Solicitar incremento presupuestario al directorio
Gobierno y Estrategia Digital	¿Qué tan madura es nuestra gobernanza de ciber?	55%	⚠ PRECAUCIÓN	Iniciar programa de madurez de gobernanza
Conocer lo que Protegemos (ID)				
Conocer lo que Protegemos	¿Tenemos inventario actualizado de activos?	65%	⚠ PRECAUCIÓN	Completar inventario de activos críticos
Conocer lo que Protegemos	¿Conocemos los riesgos de proveedores críticos?	40%	🔴 ALERTA	Realizar evaluación urgente de proveedores críticos
Conocer lo que Protegemos	¿Cuántas vulnerabilidades críticas sin resolver?	35%	🔴 ALERTA	Priorizar remediación de vulnerabilidades críticas
Defensa Activa de la Organización (PR)				
Defensa Activa de la Organización	¿Cuánto personal completó capacitación de seguridad?	78%	⚠ PRECAUCIÓN	Completar programa de concienciación pendiente
Defensa Activa de la Organización	¿Tenemos autenticación multifactor activa?	82%	✅ ÓPTIMO	Extender MFA a sistemas restantes
Defensa Activa de la Organización	¿Ciframos los datos sensibles?	70%	⚠ PRECAUCIÓN	Implementar cifrado en sistemas pendientes
Vigilancia y Alerta Temprana (DE)				
Vigilancia y Alerta Temprana	¿Qué tan rápido detectamos un incidente?	75%	⚠ PRECAUCIÓN	Reducir MTTD a menos de 24 horas
Vigilancia y Alerta Temprana	¿Cobertura de monitoreo en activos críticos?	92%	✅ ÓPTIMO	Mantener cobertura de monitoreo
Vigilancia y Alerta Temprana	¿Tiempo sin detectar a un atacante (dwell)?	60%	⚠ PRECAUCIÓN	Reducir dwell time con reglas de detección avanzadas
Respuesta ante Incidentes (RS)				
Respuesta ante Incidentes	¿Reportamos incidentes en plazos de ley?	90%	✅ ÓPTIMO	Mantener proceso de notificación ANCI
Respuesta ante Incidentes	¿Cuánto tardamos en contener un incidente?	72%	⚠ PRECAUCIÓN	Reducir MTTC con playbooks automatizados
Respuesta ante Incidentes	¿Realizamos simulacros de crisis?	50%	⚠ PRECAUCIÓN	Programar segundo ejercicio tabletop
Respuesta ante Incidentes	¿Incidentes no reportados a ANCI?	100%	✅ ÓPTIMO	Verificar proceso de clasificación de incidentes
Resiliencia y Continuidad Operacional (RC)				
Resiliencia y Continuidad Operacional	¿Recuperamos en el tiempo objetivo (RTO)?	68%	⚠ PRECAUCIÓN	Revisar y optimizar procesos de recuperación
Resiliencia y Continuidad Operacional	¿Cuánto tardamos en restaurar servicio (MTTR)?	70%	⚠ PRECAUCIÓN	Reducir MTTR con automatización de recuperación
Resiliencia y Continuidad Operacional	¿Tenemos plan BCP/DRP vigente?	75%	⚠ PRECAUCIÓN	Actualizar planes de continuidad pendientes
Resiliencia y Continuidad Operacional	¿Aprendemos de los incidentes?	55%	⚠ PRECAUCIÓN	Implementar proceso formal de lecciones aprendidas

Fuente: Elaboración propia 9

Fase 6: Validación mediante caso de estudio

El personal de seguridad no puede entregar la información de tres meses de los logs del SOC (segundo trimestre año 2026), no obstante, completan un documento de recolección de información, que permite el acceso a los datos necesarios para los cálculos de los KPIs y KRIs del modelo con datos reales del SOC para así ejecutar la Prueba de Concepto (PoC), la información está disponible en el repositorio <https://github.com/Oritapo/Unir>. Ver tablas Tabla 11 Catalogo de Indicadores KPI/KRI humanizados Dominios Gobernar (GV) –Identificar (ID)- Detectar (DE) y Tabla 12 Catalogo de Indicadores KPI/KRI humanizados Dominios (RS)- RECUPERAR (RC).

Esta fase concluye con la aplicación de la versión reducida del modelo con 20 indicadores y sus comentarios de los resultados, este es un acercamiento real para la aplicación en una organización en Chile.

4.1.4 Evaluación

Validación mediante Juicio de Expertos

Esta valoración a través de la experiencia y juicio de expertos de los especialistas proporciona una retroalimentación para definir las debilidades, defectos, oportunidades de mejora del modelo propuesto en su diseño normativo y técnico.

Selección del Panel de Expertos: con un grupo con tres (3) profesionales con experiencia probada mínimo cinco años en el área de ciberseguridad, en los perfiles Líderes de TI (IT Leads), Oficiales de Seguridad de la Información (CISO) o Auditores de Sistemas).

Instrumento de Evaluación: se utilizará un cuestionario estructurado basado en la escala de Likert de 5 puntos (1 = Totalmente en desacuerdo / 5 = Totalmente de acuerdo), organizado con cuatro interrogantes de evaluación para estas dimensiones:

- Completitud: ¿el modelo cubre todos los aspectos relevantes de la ciberseguridad organizacional?
- Utilidad práctica: ¿el modelo es aplicable en un contexto organizacional real?
- Comprensibilidad: ¿las métricas humanizadas son realmente comprensibles para perfiles no técnicos?
- Alineación normativa: ¿el modelo cubre adecuadamente los requisitos de la Ley N°21.663 y NIS2?

Ver los resultados de la validación mediante Juicio de Expertos (ver tabla 15)

La puntuación global de 4,7 obtenida es sobre 5,0 por la evaluación experta indica un alto grado de aceptación del modelo propuesto. Las dimensiones con más alta ponderación son la comprensibilidad de las métricas humanizadas con (5,0) y claridad del dashboard (4,8), lo que respalda la validez del propósito de esta investigación al hacer posible la traducción y el acercamiento técnico de la ciberseguridad a un lenguaje comprensible para la alta dirección manteniendo el rigor técnico ni la trazabilidad normativa.

5 RESULTADOS

5.1 Análisis estado de la seguridad de la organización

La vista del tablero reseña un nivel de cumplimiento global del (64, 5%) siendo un estado de alarma para la precaución, si bien existen controles técnicos y operativos, está en proceso de construcción y madurez la gobernanza que debe ser fortalecida, así como la gestión de riesgo y mejora continua. Como se explica este resultado el mejor desempeño está en Respuesta ante Incidentes (78 %), Vigilancia y Alerta Temprana (75,7 %) y Defensa Activa (76,7 %), que muestran eficacia en detección, contención y cumplimiento legal. En discrepancia la Gobernanza y Estrategia Digital (37,7 %) e Identificación de Activos y Riesgos (46,7 %) están rezagados. (Ver Figura 9 Tablero de mando estado de la seguridad)

5.2 Análisis del nivel de cumplimiento normativo ley 21.663

En cumplimiento normativa de la ley de ciberseguridad la organización expone un bajo avance global del (15%), se encuentra en una etapa inicial de la implementación y el cumplimiento de los requisitos legales. Su escenario de avance se divide de los veintes artículos evaluados, sólo 3 están cumplidos, 14 en proceso y 3 pendientes, su esfuerzo y prioridad se concentra en la adecuación progresiva de los controles y políticas exigidas por la ley. (Ver Figura 10 Tablero de mando nivel de cumplimiento normativo Ley 21.663)

5.3 Análisis integral de los indicadores humanizados

El tablero ejecutivo muestra una madurez promedio del (65 %), predomina el estado Precaución, en consecuencia, la organización muestra que está en la fase de consolidación de su gobernanza y resiliencia digital. En general, una persona con perfil no técnico puede percibir que la organización no está en riesgo extremo, no obstante, prevalecen la atención de cerrar brechas; es una ventaja que este enfoque permita comprender el estado de la seguridad en lenguaje claro, tomar decisiones informadas y asignar recursos estratégicos sin necesidad de conocimientos técnicos avanzados. (Ver Figura 11 Tablero ejecutivo Indicadores Humanizados).

Ahora evaluemos las acciones inmediatas en los estado de alerta, que afectan el desempeño de riesgo y el tránsito hacia un nuevo nivel de madurez:

- Gobierno y Estrategia Digital (GV), el estado crítico indica la falta de presupuesto con un (8 %); la acción inmediata es solicitar incremento presupuestario al directorio.
- Conocer lo que Protegemos (ID), se exponen al riesgo de proveedores (40 %) y presentan vulnerabilidades críticas sin resolver (35 %), acción inmediata gestionar y evaluar proveedores críticos y priorizar remediación de vulnerabilidades.

Las mejoras apuntan a la atención del presupuesto, proveedores, vulnerabilidades y gobernanza.

6 CONCLUSIONES Y TRABAJO FUTURO

El presente Trabajo de Fin de Estudios promueve el desarrollo de una solución viable para reducir de la brecha existente entre la información técnica de seguridad y la cap

acidad de la alta dirección para comprenderla y actuar sobre ella. Esta brecha es más que un problema de comunicación, es un riesgo organizacional, legal y técnico sin las inversiones pertinentes.

En el contexto de la Ley N°21.663 de Ciberseguridad e Infraestructura Digital de Chile, se han reforzado los vacíos legales y técnicos con el aporte de los marcos de referencia NIST CSF 2.0 y NIS2, reforzando el involucramiento activo del directorio en la gobernanza de la ciberseguridad y el acercamiento de la utilizada de la seguridad a las personas.

Este problema, se solucionó con el aporte del diseño de modelo metodológico replicable y aplicable a distintos sectores y contextos regulatorios, adaptable a varios casos de evaluación de auditoría de ciberseguridad basado en métricas de cumplimiento humanizadas con (KPIs/KRIs mínimo viable 20 indicadores sistematizado en las funciones de gobernanza, identificación, protección, detección, respuesta y recuperación; esto lo que garantiza su rigor académico y orientación hacia la resolución de un problema práctico real.

El desconocimiento u omisión de los estándares internacionales y las buenas prácticas tiene consecuencias en la organización con este impacto: graves, a corto plazo, afecta la toma de decisiones e incrementa la probabilidad de incidentes con una menor capacidad de respuesta; a mediano plazo se generan sanciones regulatorias y pérdida de confianza; y a largo plazo van adquirir una deuda técnica y limita la gobernanza lo que puede comprometer infraestructuras críticas y la continuidad operativa del Estado y la economía nacional.

Sin indicadores humanizados o indicadores estándar de (KPIs/KRIs) que midan, controlen y comuniquen la postura de riesgo, no se logrará mitigar el riesgo, ni se aprovecha la utilidad de las reglas de cumplimiento y mecanismos de protección; que deben estar alineados con las necesidades de las personas y las estrategias tecnológicas dentro lo legal, humano y técnico.

El resultado del trabajo demuestra que es posible transformar sistemáticamente los indicadores técnicos de ciberseguridad en formulaciones comprensibles y adecuados a los

marcos de control de la gestión de seguridad; para perfiles no técnicos, sin perder rigor técnico ni trazabilidad normativa.

La nueva función de gobernanza en la versión 2.0 del NIST CSF y la obligación de la directiva de cumplimiento en la Ley N°21.663, son relevantes considerando que en Chile sólo de creo un marco normativo, de cumplimiento y sancionatorio que omite el factor humano, es un ejemplo de la innovación necesaria para incorporar al usuario en la cultura y practica útil de la seguridad más allá de un directorio, al cual se le exige responsabilidad, controles técnicos: información, gestionen riesgos y se reportes ante la ANCI .

Se confirmó la demanda de atención a la brecha entre los equipos técnicos de seguridad y la alta dirección por la falta de instrumentos con enfoque humanizado, sigue siendo un problema real y reconocido en las organizaciones. Los expertos y los usuarios en todos los niveles valoraron positivamente la capacidad del modelo para «traducir y comunicar sin barreras» el riesgo técnico como información preventiva, correctiva y estratégica.

Por otro lado, los resultados antes señalados pueden ser la apertura hacia nuevas investigaciones de interés como:

La seguridad no es sólo un problema técnico, es el resultado de un ecosistema regido por la gobernanza, comunicación, cultura, legislación y tecnología; cualquier solución, metodología o marco debe incorporar la dimensión humana, porque cuestiona y traduce como puede usar lo datos y resultados para crear sus acciones y dar respuestas a sus inquietudes como usuarios.

Evaluación de opciones de mejora continua que integren controles técnicos con indicadores humanizados (KPIs/KRIs), proporcionando actualizar y ajustar las medidas de seguridad no sólo en función de las vulnerabilidades y fallas detectadas, sino también, sumando las dimensiones en la ciberseguridad respecto a métricas de cultura comportamiento de los usuarios, métricas de exposición financiera, métricas de resiliencia, métricas de proveedores críticos, métricas de contexto regulatorio entre otras.

La disponibilidad de fuentes de validación simulada abre una línea metodológica valiosa para la exploración con valores reales, sin necesidad de acceder o vulnerar los datos confidenciales de los organismos reales; se demuestra que es posible utilizar datasets públicos como Advanced SIEM Dataset, UNSW-NB15 y CIC-IDS2017 para trabajar en el diseño y validación de modelos de auditoría de ciberseguridad.

Finalmente, el modelo propuesto abre oportunidades prácticas y técnicas para las líneas de investigación y desarrollo de la humanización de las métricas con inteligencia artificial, integración de otros marcos normativos o la renovación con nuevos marcos o auditorías para añadir valor significativo a la dinámica de la ciberseguridad en instituciones.

Limitaciones del modelo

1. Complejidad de implantación: se requiere una inducción y curva de aprendizaje para la comprensión de las métricas, su fuente de recolección de datos y su integración de lo técnico-humanizado en ciberseguridad, esto evita que resulte complejo para el equipo IT de la organización.
2. Costos y recursos: adoptar el modelo implica que la organización debe invertir en tiempo, personal y herramientas de análisis como un SOC (Security Operations Center) o unidad encargada de monitorizar, detectar, analizar y responder a incidentes de ciberseguridad en tiempo real; aunque el modelo es escalable, su implementación requiere que inviertan en el arriendo del servicio con un vendor o su implementación local.
3. Resistencia organizacional: se debe sensibilizar a los responsables de áreas técnicas, mandos medios y dirección para evitar la resistencia y acción a los reportes con métricas humanizadas. Esto representa un cambio cultural al debatir lo técnico y el cuestionamiento del desempeño en el gobierno de ciberseguridad.
4. Madurez y sostenibilidad: el modelo planteado demanda un nivel mínimo de madurez en la gestión de riesgos y cumplimiento normativo en ciberseguridad para información completa y útil esperada.

7 REFERENCIAS BIBLIOGRÁFICAS

- American Psychological Association. (2020a). *Sample Analysis of Variance (ANOVA) Table*. <https://apastyle.apa.org/style-grammar-guidelines/tables-figures/sample-tables>
- American Psychological Association. (2020b). *Sample Path Model*. <https://apastyle.apa.org/style-grammar-guidelines/tables-figures/sample-figures>
- Bermejo, J., Abad, C., Bermejo, J. R., Sicilia, M. A., & Sicilia, J. A. (2020). A systematic approach to malware analysis (SAMA). *Applied Sciences*, 10(4), 1360. <https://doi.org/10.3390/app10041360>
- Center for Internet Security. (2021). *CIS Controls v8*. CIS. <https://www.cisecurity.org/controls/cis-controls>
- De Vicente, J., Bermejo, J., Bermejo, J. R., & Sicilia, J. A. (2019). The application of a new secure software development life cycle (S-SDLC) with agile methodologies. *Electronics*, 8(11), 1218. <https://doi.org/10.3390/electronics8111218>
- European Union. (2022). *Directive (EU) 2022/2555 of the European Parliament and of the Council of 14 December 2022 on measures for a high common level of cybersecurity across the Union (NIS2 Directive)*. *Official Journal of the European Union*, L 333, 80–152.
- Fonseca, L. O. (2025). *La ingeniería social y el factor humano en la ciberseguridad: la ciberinteligencia como vector de transformación del eslabón más débil a la defensa más fuerte* [Tesis de maestría, Universidad San Sebastián]. Repositorio USS.
- Gobierno de Chile. (2022). *Ley N°21.459 – Delitos Informáticos*. *Diario Oficial de la República de Chile*. <https://www.bcn.cl/leychile/navegar?idNorma=1189640>
- Gobierno de Chile. (2024). *Ley N°21.663 – Ley Marco de Ciberseguridad*. *Diario Oficial de la República de Chile*. <https://www.bcn.cl/leychile/navegar?idNorma=1226630>
- González, J. A. (2024). *Modelo de gestión de riesgos de ciberseguridad para instituciones financieras chilenas* [Tesis de maestría, Universidad de Chile]. Repositorio Académico Institucional. <https://repositorio.uchile.cl/handle/2250/180169>
- Instituto Nacional de Ciberseguridad de España. (2024). *Guías y recursos de ciberseguridad*. INCIBE. <https://www.incibe.es>
- International Organization for Standardization. (2012). *ISO/IEC 27032:2012 – Information technology – Security techniques – Guidelines for cybersecurity*. ISO.

International Organization for Standardization. (2013). *ISO/IEC 27001:2013 – Information technology – Security techniques – Information security management systems – Requirements*. ISO.

International Organization for Standardization. (2018). *ISO 19011:2018 – Guidelines for auditing management systems*. ISO.

International Organization for Standardization. (2022). *ISO/IEC 27001:2022 – Information security, cybersecurity and privacy protection – Information security management systems – Requirements*. ISO.

International Telecommunication Union. (2021). *Global Cybersecurity Index (GCI) 2021*. ITU.

ISACA. (2019). *COBIT 2019 Framework: Governance and Management Objectives*. ISACA.

Lecca-Rengifo, L. R., Paz-Medrano, H. J., & Mendoza de los Santos, A. C. (2024). Impacto de los marcos de gobierno de TI en la seguridad de la información de las organizaciones. *Revista Tecnología En Marcha*, 38(1), 93–103. <https://doi.org/10.18845/tm.v38i1.7048>

Mendívil Caldentey, J., Sanz Urquijo, B., & Gutiérrez Almazor, M. (2022). Formación y concienciación en ciberseguridad basada en competencias: una revisión sistemática de literatura. *Pixel-Bit. Revista de Medios y Educación*, 63, 197–225. <https://doi.org/10.12795/pixelbit.91640>

Mendoza Schmitz, C. (2024). *Análisis político y jurídico de la Ley 21.663* [Tesis de maestría, Universidad del Desarrollo].

Mitnick, K. D., & Simon, W. L. (2002). *The art of deception: Controlling the human element of security*. Wiley.

MITRE Corporation. (2023). *MITRE ATT&CK® Framework*. <https://attack.mitre.org>

National Institute of Standards and Technology. (2020). *Security and privacy controls for information systems and organizations (NIST Special Publication 800-53, Revision 5)*. U.S. Department of Commerce. <https://doi.org/10.6028/NIST.SP.800-53r5>

National Institute of Standards and Technology. (2024). *Cybersecurity Framework (CSF) 2.0*. U.S. Department of Commerce.

Pascoe, C., Quinn, S., & Scarfone, K. (2024). *The NIST Cybersecurity Framework (CSF) 2.0 (NIST Cybersecurity White Papers - CSWP)*. National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.CSWP.29>

Saltzer, J. H., & Schroeder, M. D. (1975). The protection of information in computer systems. *Proceedings of the IEEE*, 63(9), 1278–1308. <https://doi.org/10.1109/PROC.1975.9939>

Anexo A.

Tabla 1 CSF 2.0 Nombres e identificadores de funciones y categorías principales

Function	Category	Category Identifier
Govern (GV)	Organizational Context	GV.OC
	Risk Management Strategy	GV.RM
	Roles, Responsibilities, and Authorities	GV.RR
	Policy	GV.PO
	Oversight	GV.OV
	Cybersecurity Supply Chain Risk Management	GV.SC
Identify (ID)	Asset Management	ID.AM
	Risk Assessment	ID.RA
	Improvement	ID.IM
Protect (PR)	Identity Management, Authentication, and Access Control	PR.AA
	Awareness and Training	PR.AT
	Data Security	PR.DS
	Platform Security	PR.PS
	Technology Infrastructure Resilience	PR.IR
Detect (DE)	Continuous Monitoring	DE.CM
	Adverse Event Analysis	DE.AE
Respond (RS)	Incident Management	RS.MA
	Incident Analysis	RS.AN
	Incident Response Reporting and Communication	RS.CO
	Incident Mitigation	RS.MI
Recover (RC)	Incident Recovery Plan Execution	RC.RP
	Incident Recovery Communication	RC.CO

Fuente: (National Institute of Standards and Technology, 2024)

Tabla 2 Requisitos de la directiva NIS2

Categoría de Control	Requisitos específicos de cumplimiento NIS2
Gobernanza y Supervisión	Responsabilidad a nivel de junta directiva, políticas de gestión de riesgos, control de la cadena de suministro
Medidas Técnicas	Gestión de vulnerabilidades, diseño seguro de sistemas, cifrado, autenticación multifactor
Gestión de Incidentes	Reporte de incidentes significativos en un plazo de 24 horas a las autoridades nacionales
Continuidad del Negocio y Crisis	Políticas de respaldo, planes de recuperación ante desastres, pruebas de resiliencia
Gestión de Riesgos de la Cadena de Suministro	Procesos de evaluación de terceros y obligaciones contractuales de seguridad
Factores Humanos	Programas de concienciación y formación, canales internos de denuncia
Documentación y Monitoreo	Registros, trazabilidad de auditorías, evaluaciones periódicas de requisitos de seguridad NIS2

Fuente: Directiva NIS2 (European Union, 2022)

Tabla 3 Plantilla de auditoría de brechas para la auditoría de cumplimiento de NIS 2



NIS 2 Gap Audit template

NIS 2 Gap Analysis (cybersecurity risk management measures)

ISO 27001- ISMS Required Activities

ISO 27001:2022	Required activities	Observations and comments	Status
4. Context of the organization			
4.1 Understanding the organization and its context	The organization determines external and internal issues relevant to its purpose and affecting its ability to achieve the intended outcome(s) of the information security management system (ISMS).		
4.3 Determining the scope of the information security management system	The organization determines the boundaries and applicability of the ISMS to establish its scope.		
4.4 Information security management system	The organization establishes, implements, maintains and continually improves the ISMS.		
5. Leadership			
5.1 Leadership and commitment	Top management demonstrates leadership and commitment with respect to the ISMS.		
5.2 Policy	Top management establishes an information security policy.		
5.3 Organizational roles, responsibilities and authorities	Top management ensures that responsibilities and authorities for roles relevant to information security are assigned and communicated throughout the organization.		
6. Planning			
6.1 Actions to address risks and opportunities	When planning for the ISMS, the organization determines the risks and opportunities considering issues referred to in 4.1 and requirements referred to in 4.2. The organization defines and applies an information security risk assessment process. The organization defines and applies an information security risk treatment process.		
6.2 Information security objectives and planning to achieve them	The organization establishes information security objectives and plans to achieve them at relevant functions and levels.		
6.3 Planning of changes	The organization determines the need for changes to the information security management system, the changes are carried out in a planned manner.		
7. Support			
7.2 Competence	The organization determines the competence of persons needed for information security performance, and ensures that the persons are competent.		



NIS 2 Gap Audit template

7.3 Awareness	The persons doing work under the organization's control are made aware of the information security policy, their contribution to the effectiveness of the ISMS, benefits of improved information security performance and implications of not conforming to the requirements of the ISMS.		
7.4 Communication	The organization determines the needs for internal and external communications related to the ISMS.		
7.5 Documented information	The organization includes documented information in the ISMS as directly required by ISO/IEC 27001, as well as determined by the organization as being necessary for the effectiveness of the ISMS. When creating and updating documented information, the organization ensures its appropriate identification and description, format and media, and review and approval. The organization manages documented information throughout its lifecycle and makes it available where and when needed.		
8. Operation			
8.1 Operational planning and control	The organization plans, implements and controls the processes to meet its information security requirements and to achieve its information security objectives. The organization keeps documented information as necessary to have confidence that processes are carried out as planned. The organization controls planned changes and reviews the consequences of unintended changes, and ensures that outsourced processes are identified, defined and controlled.		
8.2 Information security risk assessment	The organization performs information security risk assessments and retains documented information on their results.		
8.3 Information security risk treatment	The organization implements the information security risk treatment plan and retains documented information on the results of the information security treatment.		
9. Performance evaluation			
9.1 Monitoring, measurement, analysis and evaluation	The organization evaluates the information security performance and the effectiveness of the ISMS.		
9.2 Internal audit	The organization conducts internal audits to provide information on conformity of the ISMS to the requirements.		
9.3 Management review	Top management reviews the ISMS at planned intervals.		
10. Improvement			
10.2 Nonconformity and corrective action	The organization reacts to nonconformities, evaluates them and takes corrections as well as corrective actions if needed.		

NIS 2 Cybersecurity risk management measures

Article	Measure	Observations and comments	Status
	Policies on risk analysis and information system security Entities must implement policies for continuous risk assessment and security of their information systems. Measure to check: Review documented risk assessments and information security policies, ensuring regular updates and adequate coverage of identified risks.		
Art.21.2 (a)	Incident handling Organizations must have effective procedures in place for detecting, responding to, and recovering from cybersecurity incidents. Measure to check: Examine incident response plans and logs, verifying timely detection and resolution of past incidents.		
Art.21.2 (b)	Organizations must have effective procedures in place for detecting, responding to, and recovering from cybersecurity incidents. Measure to check: Examine incident response plans and logs, verifying timely detection and resolution of past incidents.		
Art.21.2 (c)	Business continuity, such as backup management and disaster recovery, and crisis management Entities need to ensure business continuity through proper backup, disaster recovery plans, and crisis management strategies. Measure to check: Review the existence of backup procedures, disaster recovery testing records, and crisis management frameworks.		
Art.21.2 (d)	Supply chain security, including security-related aspects concerning the relationships between each entity and its direct suppliers or service providers Organizations should ensure supply chain security by managing risks posed by suppliers and service providers. Measure to check: Verify contracts with suppliers include security requirements and review supply chain risk assessments.		
Art.21.2 (e)	Security in network and information systems acquisition, development and maintenance, including vulnerability handling and disclosure Entities must implement security measures throughout the lifecycle of system acquisition, development, and maintenance. Measure to check: Evaluate security in development practices and vulnerability management processes.		
Art.21.2 (f)	Policies and procedures to assess the effectiveness of cybersecurity risk-management measures There must be processes in place to continuously assess and improve the effectiveness of cybersecurity controls. Measure to check: Check the frequency of risk assessments and reviews of implemented cybersecurity measures.		
Art.21.2 (g)	Basic cyber hygiene practices and cybersecurity training Basic cybersecurity practices and ongoing staff training are required to mitigate risks. Measure to check: Review training logs and cyber hygiene practices, such as password policies and regular software updates.		
Art.21.2 (h)	Policies and procedures regarding the use of cryptography and, where appropriate, encryption Entities must use cryptography and encryption where necessary to protect data. Measure to check: Verify the presence of encryption policies and implementation of cryptographic controls across critical systems.		
Art.21.2 (i)	Human resources security, access control policies and asset management Organizations should ensure that personnel security and access control are enforced, along with proper		

Get more information at [NIS2resources.eu](https://niss2resources.eu)

4

	asset management. Measure to check: Assess HR security policies, access control logs, and asset inventories.		
	The use of multi-factor authentication or continuous authentication solutions, secured voice, video and text communications and secured emergency communication systems within the entity, where appropriate Entities should implement multi-factor authentication (MFA) and secure communications channels. Measure to check: Verify the use of MFA and review the security of communication channels and emergency communication protocols.		
Art.21.2 (j)	Secure development procedures Secure development practices must be in place to mitigate risks during software and system development. Measure to check: Review the implementation of secure coding guidelines and secure development lifecycle practices.		
Art 21.3.			

Fuente Directiva NIS2 (European Union, 2022)

Tabla 4 Controles NIST 800-53

Control Family Identifier	Control Family Name	Control Family Description	Control Family Identifier	Control Family Name	Control Family Description
AC	Access Control	Policies and procedures for restricting access to systems and information	PE	Physical and Environmental Protection	Physical and environmental controls for protecting systems and facilities
AT	Awareness and Training	Security education, training, and awareness programs for personnel who use and create information systems	PL	Planning	Controls for developing and updating security and privacy plans for systems and selecting and tailoring baselines
AU	Audit and Accountability	Controls to track, document, and report on system events, logging, and monitoring	PM	Program Management	Plans and processes for ensuring governance and oversight for information security and privacy programs
CA	Assessment, Authorization, and Monitoring	Processes for assessing, testing, remediating, authorizing, and continuously monitoring security and privacy controls	PS	Personnel Security	Screening and security policies for employees and contractors throughout the lifecycle
CM	Configuration Management	Controls for establishing and maintaining the integrity of system configurations and change management	PT	PII Processing and Transparency	Privacy-specific controls for handling personally identifiable data
CP	Contingency Planning	Disaster recovery and business continuity planning in case of a security incident	RA	Risk Assessment	Processes for identifying and assessing security and privacy risks
IA	Identification and Authentication	Mechanisms for uniquely identifying and authenticating users and devices	SA	System and Services Acquisition	Controls to securely acquire and manage systems and services throughout the lifecycle
IR	Incident Response	Processes for detecting, reporting, responding to, and monitoring, and reporting security incidents	SC	System and Communications Protection	Controls for protecting information and system resources, including network security
MA	Maintenance	Controls for maintaining information systems over time	SI	System and Information Integrity	Mechanisms for protecting system integrity against threats such as malicious code and spam
MP	Media Protection	Policies and procedures for securely handling and disposing of media	SR	Supply Chain Risk Management	Controls and processes for securing third-party vendors and supply chains

Fuente: National Institute of Standards and Technology (2020)

Tabla 5 Comparación entre NIST CSF 2.0, Ley 21.663 y NIS2 frente a la humanización de métricas en ciberseguridad.

Marco / Enfoque	Coincidencias con la humanización de métricas	Contradicciones o énfasis distinto	Limitaciones / fallas detectadas	Aporte de la propuesta
NIST CSF 2.0	Integración de factores organizacionales y de gobernanza junto a controles técnicos.	Se centra en funciones técnicas (Identificar, Proteger, Detectar, Responder, Recuperar), con menor atención a la cultura organizacional.	Indicadores demasiado técnicos para directorios sin formación especializada.	Traduce métricas técnicas en indicadores comprensibles, integrando percepción y comportamiento humano.
Ley 21.663	Obliga a reportar y comunicar el estado de la ciberseguridad a entes reguladores y directorios.	Enfatiza cumplimiento normativo y sancionador, sin profundizar en métricas humanizadas.	Se limita al plano legal, sin guías prácticas para integrar factores humanos.	Complementa la ley con KPIs/KRIs sociales y culturales, fortaleciendo la gobernanza corporativa.
NIS2	Reconoce la capacitación y cultura digital como parte de la resiliencia.	Aunque menciona el factor humano, su énfasis sigue siendo regulatorio y macro.	Carece de metodologías claras para medir conciencia y participación del personal.	Operacionaliza estos aspectos mediante métricas humanizadas en dashboards ejecutivos.

Fuente: Elaboración Propia

Tabla 6 Roles y actores del modelo de auditoría de ciberseguridad

Rol	Función en el modelo	Perfil
CISO / Responsable de Ciberseguridad	Lidera la auditoría, valida indicadores y presenta resultados al directorio.	Técnico-estratégico. Conocimiento profundo de marcos NIST y normativa.
Analista de Ciberseguridad / SOC	Recopila datos, alimenta el modelo con métricas de SIEM y herramientas técnicas.	Perfil técnico operacional con acceso a plataformas SIEM/EDR.
Auditor Interno / Externo	Valida evidencias, evalúa el nivel de madurez y verifica el cumplimiento normativo.	Perfil de control con conocimiento en marcos de auditoría y normativa chilena.
Directorio / Alta Dirección	Receptor principal del dashboard ejecutivo y tomador de decisiones estratégicas.	Perfil no técnico. Requiere información humanizada y comprensible.
Responsable de Cumplimiento (Compliance)	Verifica la alineación con Ley 21.663, NIS2 y NIST CSF 2.0.	Perfil legal-normativo con conocimiento de regulación de ciberseguridad.

Fuente: Elaboración propia

Tabla 7 Dominios de control humanizados del modelo

 DOMINIOS DE CONTROL — NIST CSF 2.0 HUMANIZADOS									
Cada dominio representa una función estratégica de ciberseguridad, expresada en lenguaje comprensible para la alta dirección y el directorio.									
ID Dominio	Función NIST CSF 2.0	Nombre Humanizado	¿Qué significa para la organización?	Pregunta ejecutiva clave	Artículos Ley 21.663	Artículos NIS2	Color RAG referencia	N° KPIs	N° KRIs
GV	GOBERNAR	Gobierno y Estrategia Digital	¿Tiene la organización una estrategia de ciberseguridad aprobada por el directorio, con roles, responsabilidades y presupuesto definidos?	¿Nuestro directorio está liderando activamente la seguridad digital de la empresa?	Art. 3, 6, 7, 8, 9	Art. 20, 21(2)	Azul oscuro	4	3
ID	IDENTIFICAR	Conocer lo que Protegemos	¿Sabemos con precisión cuáles son nuestros activos críticos, qué riesgos enfrentamos y qué amenazas podrían impactarnos?	¿Sabemos exactamente qué activos y datos debemos proteger y cuáles son nuestros mayores riesgos?	Art. 4, 5, 10	Art. 21(2)(a)	Azul	4	3
PR	PROTEGER	Defensa Activa de la Organización	¿Contamos con controles técnicos y humanos (capacitación, accesos, cifrado) para reducir la probabilidad de un incidente?	¿Estamos haciendo lo suficiente para que sea muy difícil que un atacante entre a nuestros sistemas?	Art. 11, 12, 13	Art. 21(2)(b)(c)(g)(h)	Verde	5	3
DE	DETECTAR	Vigilancia y Alerta Temprana	¿Tenemos capacidad para detectar oportunamente comportamientos anómalos, intrusiones o incidentes antes de que escalen?	¿Seríamos capaces de detectar un ataque hoy, en tiempo real, antes de que cause daño mayor?	Art. 14, 15	Art. 21(2)(a)	Amarillo	4	3
RS	RESPONDER	Respuesta ante Incidentes	¿Tenemos un plan de respuesta probado, con equipos entrenados y capacidad de notificar a la autoridad (ANCI) en los plazos requeridos?	¿Si nos atacan mañana, sabemos exactamente qué hacer, quién lo hace y en cuánto tiempo?	Art. 16, 17, 18, 19	Art. 23	Naranja	4	3
RC	RECUPERAR	Resiliencia y Continuidad Operacional	¿Podemos restaurar operaciones críticas rápidamente tras un incidente y aprender para mejorar continuamente?	¿Cuánto tiempo tardaríamos en recuperarnos de un ciberataque grave sin perder datos críticos ni continuidad de servicio?	Art. 20, 21, 22	Art. 21(2)(c)	Verde oscuro	4	3

Fuente: Elaboración propia

Tabla 8 Descripción resumen marco normativo la Ley 21.663

Grupo de artículos	Contenido principal	Descripción resumida
Art. 3, 6, 7, 8, 9	Principios generales y funciones	Definen los principios rectores de la ciberseguridad en Chile, establecen competencias de la Agencia Nacional de Ciberseguridad (ANCI) y fijan responsabilidades básicas de los organismos públicos y privados.
Art. 4, 5, 10	Derechos y obligaciones	Regulan los derechos de los usuarios y las obligaciones de los prestadores de servicios esenciales, incluyendo medidas de protección y reporte de incidentes.
Art. 11, 12, 13	Supervisión y fiscalización	Establecen las facultades de la ANCI para supervisar, fiscalizar y sancionar incumplimientos, además de definir mecanismos de coordinación interinstitucional.
Art. 14, 15	Planes y políticas nacionales	Regulan la elaboración de políticas públicas y planes nacionales de ciberseguridad, asegurando alineación con estándares internacionales.
Art. 16, 17, 18, 19	Gestión de incidentes y cooperación	Definen protocolos de gestión de incidentes, cooperación internacional y coordinación con organismos de seguridad y defensa.
Art. 20, 21, 22	Régimen sancionatorio y disposiciones finales	Establecen sanciones por incumplimiento, procedimientos administrativos y disposiciones transitorias para la implementación de la ley.

Fuente: Elaboración propia

Tabla 9 Matriz de Alineación Cruzada NIST CFS 2.0-NIS2-Ley 21.663 (GOBERNAR-IDENTIFICAR-PROTEGER)

Función NIST CSF	MATRIZ DE ALINEACIÓN CRUZADA — NIST CSF 2.0 ↔ NIS2 ↔ Ley 21.663							
	Categoría NIST CSF	Subcategoría (ej.)	Obligación NIS2 equivalente	Art. NIS2	Art. Ley 21.663	Control NIST 800-53 relacionado	Nivel de alineación	Brecha detectada
GOBERNAR	Política organizacional de ciberseguridad	GV.OC-01: Misión y objetivos de ciber definidos	Estrategia nacional de ciberseg. y gobierno	Art. 20	Art. 6, 7	PM-1, PM-9	Alto ✓	Ninguna
GOBERNAR	Roles y responsabilidades	GV.RR-01: Roles asignados y comunicados	Responsabilidad del órgano de dirección	Art. 20	Art. 6	PM-2, AC-2	Alto ✓	Ninguna
GOBERNAR	Gestión de riesgos empresarial	GV.RM-01: Marco de gestión de riesgos	Gestión de riesgos cibernéticos	Art. 21(2)(a)	Art. 10	RA-1, RA-3	Medio □	Falta integración con ERM
GOBERNAR	Supervisión de la cadena de suministro	GV.SC-01: Política de cadena de suministro	Seguridad de la cadena de suministro	Art. 21(2)(d)	Art. 10	SA-9, SR-1	Bajo ●	Controles de terceros insuficientes
IDENTIFICAR	Gestión de activos	ID.AM-01: Inventario de hw/sw	Inventario de activos y sistemas	Art. 21(2)(a)	Art. 4	CM-8, PM-5	Alto ✓	Ninguna
IDENTIFICAR	Evaluación de riesgos	ID.RA-01: Vulnerabilidades identificadas	Análisis de riesgos de seguridad	Art. 21(2)(a)	Art. 5	RA-5, CA-5	Medio □	Frecuencia insuficiente
IDENTIFICAR	Mejora	ID.IM-01: Planes de mejora implementados	Mejora continua del marco de gestión	Art. 21(2)	Art. 22	CA-7, PL-2	Bajo ●	Sin proceso formal de mejora
PROTEGER	Gestión de identidades y accesos	PR.AA-01: Identidades gestionadas	Gestión de accesos y autenticación	Art. 21(2)(h)	Art. 12	AC-2, IA-2	Alto ✓	Ninguna
PROTEGER	Concienciación y formación	PR.AT-01: Concienciación del personal	Formación y concienciación en ciberseg.	Art. 21(2)(g)	Art. 11	AT-2, AT-3	Medio □	Frecuencia de formación baja
PROTEGER	Seguridad de datos	PR.DS-01: Datos en reposo protegidos	Protección de datos y privacidad	Art. 21(2)(h)	Art. 12	SC-28, MP-5	Medio □	Sin política de clasificación
PROTEGER	Seguridad de plataformas	PR.PS-01: Línea base configuración	Medidas técnicas y operativas	Art. 21(2)(b)	Art. 12	CM-2, CM-6	Alto ✓	Ninguna
PROTEGER	Resiliencia de infraestructura	PR.IR-01: Redes segmentadas y protegidas	Seguridad de redes y sistemas	Art. 21(2)(b)	Art. 12	SC-7, SC-5	Medio □	Segmentación parcial

Fuente: Elaboración propia

Tabla 10 Matriz de Alineación Cruzada NIST CFS 2.0-NIS2-Ley 21.663 (DETECTAR-RESPONDER-RECUPERAR)

↔ MATRIZ DE ALINEACIÓN CRUZADA — NIST CSF 2.0 ↔ NIS2 ↔ Ley 21.663								
Función NIST CSF	Categoría NIST CSF	Subcategoría (ej.)	Obligación NIS2 equivalente	Art. NIS2	Art. Ley 21.663	Control NIST 800-53 relacionado	Nivel de alineación	Brecha detectada
DETECTAR	Monitoreo continuo	DE.CM-01: Redes monitoreadas	Detección y respuesta a incidentes	Art. 21(2)(a)	Art. 14	AU-12, SI-4	Alto ✔	Ninguna
DETECTAR	Análisis de eventos	DE.AE-01: Eventos registrados y correlados	Gestión de eventos de ciberseguridad	Art. 21(2)(a)	Art. 14	AU-6, IR-5	Medio □	Sin SOC correlación avanzada
RESPONDER	Gestión de incidentes	RS.MA-01: Incidentes investigados	Notificación de incidentes (72h)	Art. 23	Art. 16, 18	IR-4, IR-6	Alto ✔	Ninguna
RESPONDER	Reporte de incidentes	RS.CO-01: Personal notificado	Comunicación con autoridades	Art. 23	Art. 18, 19	IR-6, IR-7	Alto ✔	Ninguna
RESPONDER	Mitigación de incidentes	RS.MI-01: Incidentes contenidos	Respuesta y mitigación	Art. 23	Art. 16	IR-4, IR-5	Medio □	Sin playbooks automatizados
RECUPERAR	Ejecución del plan de recuperación	RC.RP-01: Plan recuperación ejecutado	Continuidad operacional	Art. 21(2)(c)	Art. 20	CP-10, IR-4	Medio □	Sin RTO formalmente probados
RECUPERAR	Comunicación en recuperación	RC.CO-01: Lecciones aprendidas comunicadas	Evaluación y mejora post-incidente	Art. 21(2)(c)	Art. 22	CA-7, PM-31	Bajo ●	Sin proceso post-mortem formal

Fuente: Elaboración propia

Tabla 11 Catalogo de Indicadores KPI/KRI humanizados Dominios Gobernar (GV) –Identificar (ID)- Detectar (DE)

CATÁLOGO DE INDICADORES KPI / KRI — MÉTRICAS HUMANIZADAS												
KPI = indicador de desempeño (¿qué tan bien lo hacemos?). KRI = indicador de riesgo (¿qué tan expuestos estamos?). Semáforo: ■ ≥80% · ■ 50-79% · ● <50%												
Dominio	ID	Ti	Nombre Humanizado del Indicador	¿Qué mide en lenguaje simple?	Fórmula de Cálculo	Fuente de Datos	Frecuen	● Alerta	■ Precauc	■ Óptimo	Alineación Ley 21.663	Alineación NI
GV	GV-KPI-01	KPI	¿Tenemos estrategia de ciberseguridad aprobada?	Porcentaje de políticas de ciberseguridad formalmente aprobadas por el directorio	(N° políticas aprobadas / N° políticas requeridas) × 100	Actas directorio / SGD	Semestral	<50%	50-79%	≥80%	Art. 6, 7	Art. 20
GV	GV-KPI-02	KPI	¿Tenemos presupuesto dedicado a seguridad?	Porcentaje del presupuesto TI asignado específicamente a ciberseguridad	(Presupuesto ciber / Presupuesto TI total) × 100	ERP / Control de gestión	Anual	<5%	5-9%	≥10%	Art. 8	Art. 21(2)
GV	GV-KRI-02	KRI	¿Qué tan madura es nuestra gobernanza de ciber?	Nivel de madurez del modelo de gobernanza (escala 1 a 5)	Puntuación obtenida en evaluación de madurez / 5 × 100	Auditoría interna	Anual	<40%	40-69%	≥70%	Art. 6, 8	Art. 20
ID	ID-KPI-01	KPI	¿Tenemos inventario actualizado de activos?	Porcentaje de activos de información críticos inventariados y categorizados	(Activos inventariados / Total activos estimados) × 100	CMDB / Inventario	Trimestral	<60%	60-79%	≥80%	Art. 4, 5	Art. 21(2)(a)
ID	ID-KPI-04	KPI	¿Conocemos los riesgos de nuestra cadena de proveedores?	Porcentaje de proveedores críticos con evaluación de riesgo cibernético	(Proveedores evaluados / Total proveedores críticos) × 100	Contratos / GRC	Anual	<40%	40-69%	≥70%	Art. 4	Art. 21(2)(d)
ID	ID-KRI-01	KRI	¿Cuántas vulnerabilidades críticas conocidas tenemos sin resolver?	Número de vulnerabilidades CVSS ≥7 sin remediar en activos críticos	N° vulnerabilidades críticas abiertas > 30 días	Scanner vuln / SIEM	Semanal	>20	>10	0-10	Art. 5	Art. 21(2)(a)
PR	PR-KPI-01	KPI	¿Cuánto del personal completó su capacitación de seguridad?	Porcentaje del personal que completó la formación obligatoria de ciberseguridad	(Empleados formados / Total empleados) × 100	LMS / RRHH	Semestral	<60%	60-79%	≥80%	Art. 11	Art. 21(2)(g)
PR	PR-KPI-02	KPI	¿Tenemos autenticación robusta implementada?	Porcentaje de sistemas críticos con autenticación multifactor (MFA) activa	(Sistemas con MFA / Total sistemas críticos) × 100	IAM / AD	Trimestral	<60%	60-79%	≥80%	Art. 12	Art. 21(2)(h)
PR	PR-KPI-05	KPI	¿Ciframos los datos sensibles en tránsito y en reposo?	Porcentaje de datos sensibles protegidos con cifrado según política	(Volumen datos cifrados / Total datos sensibles) × 100	DLP / IAM	Trimestral	<60%	60-79%	≥80%	Art. 12	Art. 21(2)(h)
DE	DE-KPI-02	KPI	¿Qué tan rápido detectamos un incidente?	Tiempo promedio desde que ocurre un incidente hasta que es detectado (MTTD)	Suma tiempos detección / N° incidentes detectados (en horas)	SIEM / Ticketing	Mensual	>72h	24-72h	<24h	Art. 14	Art. 21(2)(a)
DE	DE-KPI-04	KPI	¿Tenemos cobertura de monitoreo en activos críticos?	Porcentaje de activos críticos cubiertos por monitoreo continuo (SIEM/EDR)	(Activos monitoreados / Total activos críticos) × 100	SIEM / EDR	Mensual	<70%	70-89%	≥90%	Art. 14	Art. 21(2)(a)
DE	DE-KRI-03	KRI	¿Cuánto tiempo pasa un atacante sin ser detectado?	Tiempo promedio en que un incidente existió antes de ser detectado (dwell time)	Suma dwell time incidentes / N° incidentes (en días)	SIEM / IIR	Mensual	>30d	7-30d	<7d	Art. 15	Art. 21(2)(a)

Fuente: Elaboración propia

Tabla 12 Catalogo de Indicadores KPI/KRI humanizados Dominios (RS)-RECUPERAR (RC)

CATÁLOGO DE INDICADORES KPI / KRI — MÉTRICAS HUMANIZADAS												
KPI = indicador de desempeño			(¿qué tan bien lo hacemos?). KRI = indicador de riesgo (¿qué tan expuestos estamos?). Semáforo: ≥80% 50-79% <50%									
Dominio	ID	Tipo	Nombre Humanizado del Indicador	¿Qué mide en lenguaje simple?	Fórmula de Cálculo	Fuente de Datos	Frecuencia	Alerta	Precaución	Óptimo	Alineación Ley 21.663	Alineación NI
RS	RS-KPI-02	KPI	¿Reportamos incidentes en los plazos de ley?	Porcentaje de incidentes notificados a la ANCI dentro del plazo legal (72h)	(Incidentes notificados en plazo / Total incidentes notificables) × 100	Registro IR / ANCI	Mensual	<60%	60-89%	≥90%	Art. 18, 19	Art. 23
RS	RS-KPI-03	KPI	¿Cuánto tardamos en contener un incidente?	Tiempo promedio desde detección hasta contención del incidente (MTTC)	Suma tiempos contención / N° incidentes contenidos (en horas)	SIEM / Ticketing	Mensual	>24h	8-24h	<8h	Art. 16	Art. 23
RS	RS-KPI-04	KPI	¿Realizamos ejercicios de simulación de crisis?	Número de simulacros o ejercicios tabletop de respuesta a incidentes realizados	N° ejercicios completados en el período	Actas ejercicios	Anual	0	1	≥2	Art. 17	Art. 21(2)(c)
RS	RS-KRI-03	KRI	¿Cuántos incidentes no reportados a ANCI detectamos?	Número de incidentes que debían reportarse a ANCI y no fueron reportados	N° incidentes notificables no reportados detectados en revisión	Auditoría / ANCI	Mensual	>0	-	0	Art. 18, 19	Art. 23
RC	RC-KPI-01	KPI	¿Recuperamos operaciones dentro del tiempo objetivo (RTO)?	Porcentaje de incidentes en que la recuperación se logró dentro del RTO definido	(Recuperaciones en RTO / Total incidentes con RTO) × 100	SIEM / BCP	Mensual	<60%	60-79%	≥80%	Art. 20	Art. 21(2)(c)
RC	RC-KPI-03	KPI	¿Tenemos un plan de continuidad operacional vigente?	Porcentaje de servicios críticos cubiertos por un plan BCP/DRP actualizado	(Servicios con BCP/DRP vigente / Total servicios críticos) × 100	BCP / DRP docs	Semestral	<60%	60-79%	≥80%	Art. 21	Art. 21(2)(c)
RC	RC-KPI-04	KPI	¿Aprendemos de los incidentes para mejorar?	Porcentaje de lecciones aprendidas de incidentes que generaron mejoras implementadas	(Lecciones aprendidas implementadas / Total lecciones documentadas) × 100	Registro IR / CISO	Trimestral	<50%	50-79%	≥80%	Art. 22	Art. 21(2)(c)
RC	RC-KRI-01	KRI	¿Cuánto tiempo tardamos en restaurar servicio (MTTR)?	Tiempo promedio de recuperación total de servicios tras un incidente	Suma tiempos recuperación / N° incidentes resueltos (en horas)	SIEM / BCP	Mensual	>48h	8-48h	<8h	Art. 20	Art. 21(2)(c)

Fuente: Elaboración propia

Tabla 13 Plantilla de Auditoría de Brechas

 PLANTILLA DE AUDITORÍA DE BRECHAS — NIVEL DE MADUREZ (1-5)										
Escala: 1=Inicial (ad hoc) · 2=Gestionado · 3=Definido · 4=Cuantificado · 5=Optimizado. Ingrese el nivel actual (1-5) y el nivel objetivo.										
Dominio	Área de Control	Control / Requisito Humanizado	Ley 21.663	NIS2	Nivel Actual (1-5)	Nivel Objetivo (1-5)	Brecha (Gap)	Prioridad	Hallazgo / Evidencia	Plan de Acción
GV	Cumplimiento	Programa de gestión de cumplimiento normativo activo	Art. 9	Art. 32	2	4	2	Sin proceso de monitoreo regulatorio	Implementar GRC con seguimiento ANCI	
ID	Activos	Inventario de activos críticos completo y actualizado	Art. 4	Art. 21(2)(a)	2	4	2	Inventario desactualizado (> 6 meses)	Ejecutar desduplicamiento automático de activos	
ID	Riesgos	Evaluaciones de riesgo periódicas y documentadas	Art. 5	Art. 21(2)(a)	2	4	2	Última evaluación hace 18 meses	Realizar evaluación de riesgo completa Q3 2026	
ID	Proveedores	Evaluación de riesgos de proveedores críticos	Art. 10	Art. 21(2)(d)	1	3	2	Sin evaluación de ningún proveedor	Crear programa de TPRM inmediatamente	
PR	Formación	Programa de concienciación y capacitación del personal	Art. 11	Art. 21(2)(g)	3	4	1	Solo 1 capacitación anual	Implementar micro-capacitaciones mensuales	
PR	Accesos	Autenticación multifactor (MFA) en sistemas críticos	Art. 12	Art. 21(2)(h)	3	5	2	MFA solo en correo corporativo	Extender MFA a todos los sistemas críticos	
PR	Parches	Gestión de vulnerabilidades y parches en plazo	Art. 12	Art. 21(2)(b)	3	4	1	10% de parches críticos pendientes	Automatizar proceso de patch management	
PR	Cifrado	Cifrado de datos sensibles en tránsito y en reposo	Art. 12	Art. 21(2)(h)	2	4	2	Sin cifrado en bases de datos legacy	Plan de migración a almacenamiento cifrado	
DE	SIEM	Monitoreo continuo con SIEM operativo 24/7	Art. 14	Art. 21(2)(a)	3	4	1	SIEM solo monitorea horario laboral	Configurar alertas 24/7 y turno NOC	
DE	Detección	Tiempo de detección de incidentes (MTTD < 24h)	Art. 14	Art. 21(2)(a)	2	4	2	MTTD promedio > 72 horas	Implementar reglas de correlación avanzadas	
DE	Threat Intel	Fuentes de inteligencia de amenazas integradas	Art. 15	Art. 21(2)(a)	1	3	2	Sin feeds CTI integrados	Integrar mínimo 3 fuentes CTI al SIEM	
RS	Plan IR	Plan de respuesta a incidentes documentado y probado	Art. 16	Art. 23	3	5	2	Plan existente pero sin ejercicios	Realizar ejercicio tabletop semestral	
RS	Notificación	Protocolo de notificación a ANCI en 72 horas	Art. 18, 19	Art. 23	4	5	1	Protocolo existe, no siempre respeta	Automatizar alerta de obligación de reporte	
RS	Simulacros	Ejercicios de simulación de crisis realizados	Art. 17	Art. 21(2)(c)	1	3	2	Sin ningún ejercicio realizado	Planificar 2 ejercicios tabletop anuales	
RC	BCP/DRP	Plan de continuidad operacional con RTO/RPO definidos	Art. 20	Art. 21(2)(c)	2	4	2	BCP sin RTO/RPO formalizados	Definir RTO/RPO por servicio crítico	
RC	Backups	Pruebas de restauración de backup periódicas	Art. 20	Art. 21(2)(c)	3	5	2	Backups sin prueba de restauración	Implementar pruebas mensuales de restore	
RC	Mejora	Ciclo de mejora continua basado en incidentes	Art. 22	Art. 21(2)(c)	1	3	2	Sin proceso post-mortem formal	Implementar proceso de lecciones aprendidas	

Fuente: Elaboración propia

Tabla 14 Plantilla Cuadro de Mando Ejecutivo de Ciberseguridad

CUADRO DE MANDO EJECUTIVO DE CIBERSEGURIDAD											
Ingrese el valor de cumplimiento real (0-100%) para cada indicador. El semáforo se actualizará automáticamente.											
Dominio	ID Indicador	Nombre Humanizado	Tipo	Valor Real (%)	▮ Semáforo	Umbral Alerta	Umbral Precaución	Umbral Óptimo	Estado Narrativo	Prioridad	Acción Recomendada
GV	GV-KPI-01	¿Tenemos estrategia de ciberseguridad aprobada?	KPI	50	▮ PRECAUCIÓN	<50%	50-79%	≥80%	⚠ Requiere atención	Alta	Revisar políticas pendientes de aprobación
GV	GV-KPI-02	¿Tenemos presupuesto dedicado a seguridad?	KPI	8	● ALERTA	<5%	5-9%	≥10%	🚨 Acción urgente requerida	Alta	Solicitar incremento presupuestario al directorio
GV	GV-KRI-02	¿Qué tan madura es nuestra gobernanza de ciber?	KRI	55	▮ PRECAUCIÓN	<40%	40-69%	≥70%	⚠ Requiere atención	Media	Iniciar programa de madurez de gobernanza
ID	ID-KPI-01	¿Tenemos inventario actualizado de activos?	KPI	65	▮ PRECAUCIÓN	<60%	60-79%	≥80%	⚠ Requiere atención	Alta	Completar inventario de activos críticos
ID	ID-KPI-04	¿Conocemos los riesgos de proveedores críticos?	KPI	40	● ALERTA	<40%	40-69%	≥70%	🚨 Acción urgente requerida	Crítica	Realizar evaluación urgente de proveedores críticos
ID	ID-KRI-01	¿Cuántas vulnerabilidades críticas sin resolver?	KRI	35	● ALERTA	<50%	50-79%	≥80%	🚨 Acción urgente requerida	Crítica	Priorizar remediación de vulnerabilidades críticas
PR	PR-KPI-01	¿Cuánto personal completó capacitación de seguridad?	KPI	78	▮ PRECAUCIÓN	<60%	60-79%	≥80%	⚠ Requiere atención	Alta	Completar programa de concienciación pendiente
PR	PR-KPI-02	¿Tenemos autenticación multifactor activa?	KPI	82	▮ ÓPTIMO	<60%	60-79%	≥80%	✓ En cumplimiento	Baja	Extender MFA a sistemas restantes
PR	PR-KPI-05	¿Ciframos los datos sensibles?	KPI	70	▮ PRECAUCIÓN	<60%	60-79%	≥80%	⚠ Requiere atención	Alta	Implementar cifrado en sistemas pendientes
DE	DE-KPI-02	¿Qué tan rápido detectamos un incidente?	KPI	75	▮ PRECAUCIÓN	<70%	70-89%	≥90%	⚠ Requiere atención	Alta	Reducir MTTD a menos de 24 horas
DE	DE-KPI-04	¿Cobertura de monitoreo en activos críticos?	KPI	92	▮ ÓPTIMO	<70%	70-89%	≥90%	✓ En cumplimiento	Baja	Mantener cobertura de monitoreo
DE	DE-KRI-03	¿Tiempo sin detectar a un atacante (dwell)?	KRI	60	▮ PRECAUCIÓN	<50%	50-79%	≥80%	⚠ Requiere atención	Alta	Reducir dwell time con reglas de detección avanzadas
RS	RS-KPI-02	¿Reportamos incidentes en plazos de ley?	KPI	90	▮ ÓPTIMO	<60%	60-89%	≥90%	✓ En cumplimiento	Baja	Mantener proceso de notificación ANCI
RS	RS-KPI-03	¿Cuánto tardamos en contener un incidente?	KPI	72	▮ PRECAUCIÓN	<70%	70-89%	≥90%	⚠ Requiere atención	Alta	Reducir MTTC con playbooks automatizados
RS	RS-KPI-04	¿Realizamos simulacros de crisis?	KPI	50	▮ PRECAUCIÓN	0%	1%	≥2	⚠ Requiere atención	Alta	Programar segundo ejercicio tabletop
RS	RS-KRI-03	¿Incidentes no reportados a ANCI?	KRI	100	▮ ÓPTIMO	<50%	50-79%	≥80%	✓ En cumplimiento	Baja	Verificar proceso de clasificación de incidentes
RC	RC-KPI-01	¿Recuperamos en el tiempo objetivo (RTO)?	KPI	68	▮ PRECAUCIÓN	<60%	60-79%	≥80%	⚠ Requiere atención	Alta	Revisar y optimizar procesos de recuperación
RC	RC-KRI-01	¿Cuánto tardamos en restaurar servicio (MTTR)?	KRI	70	▮ PRECAUCIÓN	<50%	50-79%	≥80%	⚠ Requiere atención	Media	Reducir MTTR con automatización de recuperación
RC	RC-KPI-03	¿Tenemos plan BCPIDRP vigente?	KPI	75	▮ PRECAUCIÓN	<60%	60-79%	≥80%	⚠ Requiere atención	Alta	Actualizar planes de continuidad pendientes
RC	RC-KPI-04	¿Aprendemos de los incidentes?	KPI	55	▮ PRECAUCIÓN	<50%	50-79%	≥80%	⚠ Requiere atención	Alta	Implementar proceso formal de lecciones aprendidas
CUMPLIMIENTO GLOBAL PROMEDIO — NÚCLEO 20				64,5	▮ PRECAUCIÓN						

Fuente: Elaboración propia

Tabla 15 Resultados de la evaluación por juicio de expertos (escala Likert 1-5)

Dimensión evaluada	E1	E2	E3	Promedio (5,0)
Compleitud del catálogo de dominios	5	4	5	4,6
Utilidad para la toma de decisiones ejecutivas	5	5	4	4,6
Comprensibilidad de las métricas humanizadas	5	5	5	5,0
Alineación con Ley N°21.663 (Chile)	5	4	5	4,6
Alineación con Directiva NIS2	4	5	5	4,6
Viabilidad de implementación en organización real	5	5	5	5,0
Claridad del dashboard ejecutivo	5	4	5	4,8
PUNTUACIÓN GLOBAL				4,7

Fuente: Elaboración Propia

Table 16 Instrumento de Recolección de Información del Modelo

INSTRUMENTO DE RECOLECCIÓN DE INFORMACIÓN DEL MODELO					
Dominio	ID Indicador	Pregunta ejecutiva humanizada	Fuente alternativa de datos	Formato de respuesta	Valor Real
GV	GV-KPI-01	¿Tenemos estrategia de ciberseguridad aprobada por el directorio?	Actas directorio / SGD	% políticas aprobadas	50%
GV	GV-KPI-02	¿Tenemos presupuesto dedicado a seguridad?	ERP / Control de gestión	% presupuesto TI asignado	8%
GV	GV-KRI-02	¿Qué tan madura es nuestra gobernanza de ciberseguridad?	Auditoría interna	Escala 1-5 convertida a %	55%
ID	ID-KPI-01	¿Tenemos inventario actualizado de activos críticos?	CMDB / Inventario	% activos inventariados	65%
ID	ID-KPI-04	¿Conocemos los riesgos de nuestra cadena de proveedores?	Contratos / GRC	% proveedores evaluados	40%
ID	ID-KRI-01	¿Cuántas vulnerabilidades críticas conocidas tenemos sin resolver?	Scanner vuln / SIEM	N° vulnerabilidades críticas abiertas	35
PR	PR-KPI-01	¿Cuánto del personal completó su capacitación de seguridad?	LMS / RRHH	% empleados capacitados	78%
PR	PR-KPI-02	¿Tenemos autenticación multifactor activa en sistemas críticos?	IAM / AD	% sistemas con MFA	82%
PR	PR-KPI-05	¿Ciframos los datos sensibles en tránsito y reposo?	DLP / IAM	% datos cifrados	70%
DE	DE-KPI-02	¿Qué tan rápido detectamos un incidente? (MTTD)	SIEM / Ticketing	Horas promedio	75h
DE	DE-KPI-04	¿Tenemos cobertura de monitoreo en activos críticos?	SIEM / EDR	% activos monitoreados	92%
DE	DE-KRI-03	¿Cuánto tiempo pasa un atacante sin ser detectado? (dwell time)	SIEM / IR	Días promedio	60d
RS	RS-KPI-02	¿Reportamos incidentes en los plazos de ley (72h)?	Registro IR / ANCI	% incidentes reportados en plazo	90%
RS	RS-KPI-03	¿Cuánto tardamos en contener un incidente? (MTTC)	SIEM / Ticketing	Horas promedio	72h
RS	RS-KPI-04	¿Realizamos ejercicios de simulación de crisis?	Actas ejercicios	N° ejercicios realizados	1 ejercicio (50%)
RS	RS-KRI-03	¿Cuántos incidentes no reportados a ANCI detectamos?	Auditoría / ANCI	N° incidentes no reportados	0
RC	RC-KPI-01	¿Recuperamos operaciones dentro del tiempo objetivo (RTO)?	SIEM / BCP	% incidentes recuperados en RTO	65%
RC	RC-KRI-01	¿Cuánto tiempo tardamos en restaurar servicio (MTTR)?	SIEM / BCP	Horas promedio	72h
RC	RC-KPI-03	¿Tenemos un plan de continuidad operacional vigente?	BCP / DRP docs	% servicios críticos con plan	65%
RC	RC-KPI-04	¿Aprendemos de los incidentes para mejorar?	Registro IR / CISO	% lecciones implementadas	60%

Fuente: Elaboración propia

Tabla 17 Indicadores humanizados vs técnicos

Indicador humanizado	Homólogo técnico
¿Tenemos estrategia de ciberseguridad aprobada?	% de políticas de ciberseguridad aprobadas por el directorio
¿Tenemos presupuesto dedicado a seguridad?	% del presupuesto TI asignado a ciberseguridad
¿Qué tan madura es nuestra gobernanza de ciber?	Nivel de madurez del modelo de gobernanza (escala 1–5)
¿Tenemos inventario actualizado de activos?	% de activos críticos inventariados en CMDB
¿Conocemos los riesgos de nuestra cadena de proveedores?	% de proveedores críticos con evaluación de riesgo
¿Cuántas vulnerabilidades críticas conocidas tenemos sin resolver?	Nº de vulnerabilidades CVSS ≥ 7 abiertas >30 días
¿Cuánto del personal completó su capacitación de seguridad?	% de empleados que completaron formación obligatoria
¿Tenemos autenticación robusta implementada?	% de sistemas críticos con MFA activo
¿Ciframos los datos sensibles en tránsito y en reposo?	% de datos sensibles cifrados según política
¿Qué tan rápido detectamos un incidente?	MTTD (Mean Time to Detect) en horas
¿Tenemos cobertura de monitoreo en activos críticos?	% de activos críticos monitoreados por SIEM/EDR
¿Cuánto tiempo pasa un atacante sin ser detectado?	Dwell time promedio en días
¿Reportamos incidentes en los plazos de ley?	% de incidentes notificados a ANCI en $\leq 72h$
¿Cuánto tardamos en contener un incidente?	MTTC (Mean Time to Contain) en horas
¿Realizamos ejercicios de simulación de crisis?	Nº de simulacros tabletop realizados por año
¿Cuántos incidentes no reportados a ANCI detectamos?	Nº de incidentes notificables no reportados
¿Recuperamos operaciones dentro del tiempo objetivo (RTO)?	% de incidentes recuperados dentro del RTO definido
¿Tenemos un plan de continuidad operacional vigente?	% de servicios críticos con BCP/DRP actualizado
¿Aprendemos de los incidentes para mejorar?	% de lecciones aprendidas implementadas
¿Cuánto tiempo tardamos en restaurar servicio (MTTR)?	MTTR (Mean Time to Recover) en horas

Fuente: Elaboración propia